



ICT Risk AI Guideline

Version: 1.0

Valid From Date: 01.04.2026

Last Review Date: 11.03.2026

Notes: This written rule uses gender-neutral and inclusive language. Whenever possible, the generic masculine is avoided and all employees of any gender identity (m/f/d) are addressed.

Content changes compared to the previous document version are highlighted in color. Due to the new creation, this has been omitted in this version.

Content

1	Purpose, Objectives and Basis	3
1.1	Purpose and Objectives	3
1.2	Basis of this Written Rule	4
2	Functional Scope and Target Groups	5
2.1	Functional Scope of applicability	5
2.2	Target groups	5
2.3	Transition period	6
3	Definitions	7
3.1	Requirements	7
3.2	Explanation of requirements and key definitions	8
4	Requirements	9
4.1	AI Governance, Transparency and Literacy	9
4.2	AI System Classification and Applicability	16
4.3	Risk Management and Oversight	20
4.4	Technical and Operational Controls	24
4.5	Compliance and Regulatory Alignment	36
5	Specifications of requirements	51
5.1	Prohibited AI practices	51
5.2	High-risk AI systems	52
5.3	Information to be submitted upon the registration of high-risk AI	54
5.4	Testing of high-risk AI systems in real world conditions	55
5.5	Information to be submitted upon the registration of high-risk AI systems	56
5.6	Conformity based on an assessment	57
5.7	Technical documentation for providers of general-purpose AI models	58
5.8	Transparency information for providers of GPAI to downstream providers	59
6	Roles and Responsibilities	61
6.1	Creator	61
6.2	Guideline Owner	61
7	Appendix	62
7.1	Contact Information	62
7.2	Document History	62
7.3	Related Written Rules	63
7.4	Supporting Document(s)	63
7.5	Abbreviations	63

1 Purpose, Objectives and Basis

1.1 Purpose and Objectives

The ICT Risk AI Guideline (hereinafter “Guideline”) establishes control requirements for DBAG and/or adopting Legal Entities within DBG (refers only to Legal Entities that have ratified the Guideline at hand) and provides criteria for fulfilling the control requirements.

The purpose of the Guideline is to effectuate the below listed Minimum Requirements, stipulated in the ICT Risk Management Policy (structured into Core Functions), acting as objectives to the Guideline and the control requirements at hand:

Core Function	Minimum Requirement	ICT Risk Management Policy chapter
Govern	2. Allocate roles and responsibilities as detailed in chapter 5 in the ICT Risk Management Policy.	4.1
Govern	6. Have in place a mechanism to define and document responsibilities for implementing control requirements both within and outside IT and IS (e.g. HR). This can be documented e.g. as part of the Mandatory Control Framework (MCF).	4.1
Identify	2. Identify and record assets (e.g. data, hardware, software, systems, facilities, services, people) and classify these assets with their relative importance to organizational objectives (including security objectives) and the organization’s risk strategy.	4.2
Identify	4. Establish an ICT risk management process and perform ICT risk assessment on a regular basis and in the event of major changes, considering threats and vulnerabilities covering different IT assets (e.g. applications) and Non-IT assets (e.g. buildings, rooms) in a consistent way taking into consideration asset-specific differences in the assessment approach.	4.2
Protect	1. Design and implement ICT risk management control requirements to achieve the protection goals and integrating them to the ICT risk framework. These control requirements are including but not limited to ICT operations and physical and environmental security, network and infrastructure management, encryption and cryptographic controls, identity management and logical/physical access control, software development, change and project management, threat management, patch and vulnerability management, human resources, and third-party management.	4.3
Detect	2. Put in place sufficient capabilities to monitor user activity, the occurrence of anomalous events, in particular cyber-attacks	4.4

Note: The full list of Core Functions and Minimum Requirements is stipulated in the ICT Risk Management Policy.

Note on other relevant written documents

Besides this Guideline other written rules apply in parallel:

- Any processing of personal data within an AI system is subject to the requirements of DBG's written rules applicable to personal data protection - Data Protection Policy (Personal Data) from Group Data Protection. This policy defines a minimum standard for a mutual understanding and management of risks in the area of Personal Data Protection (Data Privacy) within DBAG and/or adopting legal entity within DBG. Subordinated written rules document is Guideline on Data Protection.
- The "Policy on IT Compliance, Artificial Intelligence and Segregation of Duties". from Group Compliance, governs the responsible and ethical use of artificial intelligence at DBAG and across all legal entities that have adopted it. Subordinated written rules document is "Guideline on Artificial Intelligence"

Together with other ICT Risk Management Guidelines this Guideline forms ICT Risk part of Quality Management System (QMS) for AI and covers the entire lifecycle of AI systems.

If subject to other QMS obligations under Union financial services law, EU AI Act-specific elements (excluding risk management, post-market monitoring, and serious incident reporting) are integrated into the existing frameworks.

Note on Chapter 5 to this Guideline

In Chapter 5 Specifications of requirements, we list detailed specifications, which were considered too detailed for criteria in Chapter 4 but are to be followed when fulfilling Control requirements.

1.2 Basis of this Written Rule

The basis for this Guideline is the ICT Risk Management Policy.

2 Functional Scope and Target Groups

2.1 Functional Scope of applicability

Entity	DBAG and/or adopting LE within DBG
Area	DBAG CIO / COO Division; Chief Risk Officer Area; or any other area that manages or owns Artificial Intelligence topic

Table 1: Scope

2.2 Target groups

Within the scope of the current ICT Risk AI Guideline below is addressed the list of applicable target groups and operation areas¹:

Target group	Key message
Management Body	To ensure the awareness of the importance of artificial intelligence for strategic decision-making.
ICT Risk Oversight	To oversee the enforcement of security policies and ensure that all activities, changes and developments which include artificial intelligence comply with DBG cybersecurity framework.
ICT Operational Management	To implement and manage changes that include artificial intelligence and ensure they align with existing IT infrastructure and security standards.
Business Management	To implement and manage artificial intelligence solutions and controls and monitor for potential issues ensuring the security and integrity of systems and data.

Table 2: Target groups

¹ For LE Guidelines adoption process the target groups should be adjusted according to organizational structure of the LE.

2.3 Transition period

The grace period for new requirements commences from the “valid from” date stated on the cover page. The compliance dates for control requirements defined in this version of the Guideline are defined as follows:

- For control requirements related to the articles of EU AI Act that are already in place* the compliance date equals the “valid from” date.
- For control requirements related to the articles of EU AI Act that are designated to be in place from certain date in the future the compliance date equals this date (given in brackets).
- For new and changed control requirements that are not subject to EU AI Act the compliance date is generally 90 calendar days after the “valid from” date unless otherwise stated in brackets after the control requirements. These control requirements are marked with ●.
- For Legal Entities that have not previously approved the IT-related requirements and are therefore addressing these requirements for the first time, a grace period of 90 days may be granted at the discretion of the Legal Entity. Requirements based on the articles of EU AI Act are exempt from this grace period.

For a **compliance date** exceeding 180 calendar days implementation timeline, a Board approval is required.

** Control requirements ID2, ID5, ID6, ID25, ID26, and ID27 were already in place at the time of the initial publication of this Guideline.*

3 Definitions

3.1 Requirements

Control requirement

The control requirements define the organizational, process or technical controls to be implemented by the control owner to achieve compliance with this Guideline.

Criteria

Criteria define the measures that ‘must’ or ‘should’ be taken to fulfill the control requirement.

Level of obligation

With respect to requirements and criteria, the following terms are used to define the level of obligation, provided for the implementation of a particular requirement or criteria:

- **“must”**: Mandatory control requirements / criteria derived directly from law, regulations, or internal specifications that the legal entity must comply with. Incompliance could result in consequences with external regulators and Internal Audit.
- **“should”**: Non-mandatory control requirements / criteria derived from best-practice frameworks or equivalent sources that the legal entity does not have to necessarily comply with. Under specific circumstances there may exist valid reasons to ignore a particular control requirement, but the full implications must be understood and carefully weighed.

Independent of the level of obligation of a given requirement or criteria, it is allowed to deviate from single requirements or criteria in individual cases. However, a control requirement deviation always requires the conduction of a risk assessment and risk management including adequate risk acceptance and/or mitigation.

Any deviation from the Guideline denotes an exemption. The respective Information Owner makes decisions on such exemptions. Information Owners can only decide on risks with impact exclusively in their area of responsibility.

Responsibilities

The responsibility for fulfilling control requirements may be distributed across the organization, e.g., multiple Departments, Sections, or Units. In some cases, one Unit may be responsible for both the design and implementation of measures. In other cases, one Unit may be responsible for the design of measures, and another Unit may be responsible for the implementation of the measures. In addition, multiple Units may be responsible to collectively fulfill one requirement.

The precise responsibilities are to be defined in the underlying Procedure documents (e.g. via RACI matrices).

The ICS, among its various functionalities, registers Process Operators (PO) and Risk Representatives (RRs) mapped to the corresponding processes, controls, and risks which the RRs and/or POs are responsible for managing on behalf of the part of the organization that utilize their services (e.g. Asset Owners). For more information on ICS, please refer to the DBG ICS Guideline.

3.2 Explanation of requirements and key definitions

Control requirements are defined in a standardized format and are structured into the following components:

<Specify ID: xx (version x)>	<Name of control requirement (e.g. Access to production data)>
1	<Description of the control requirement>
1.1 1.1.1	<Lists the criteria applying to the control requirement> <Lists the sub-criteria applying to the control requirement>
Protection goals <Specifies the protection goal of the control requirement e.g., CIAA (Confidentiality, Integrity, Availability, Authenticity)>	Key references <Lists key regulatory references and industry best practice requirements affecting this control requirement (e.g., ISO/IEC 27001:2022 A.5.10, A.8.1)>
Start date of applicability: <Specifies the date of the validity based on EU AI Act>	Relevant for role of DBG/LE as <Defines the relevance of Control Requirements for LE in its role as Provider, Deployer for each Asset as defined in ICT Glossary and based on EU AI Act (e.g.,)>

The terms in this document are defined in the overall ICT Risk Glossary, which is provided on the Intranet website.

4 Requirements

4.1 AI Governance, Transparency and Literacy

ID: 1 (version 1.0)	AI Resource and Asset Management
1	Asset inventories of all AI Systems, General-purpose AI (GPAI) systems, AI Models and AI Agents in development or in use must be maintained. Aside from control requirements from ICT Asset Management additional attributes must be maintained as defined in criteria below.
1.1	In addition to control requirements from ICT Asset Management, the dedicated or centralized asset inventory must further include, at a minimum, the following information for each AI Model: – Model Provenance - The origin of the model i.e. In-house Developed, Third-party Custom-developed, Open-source (Pre-trained), Commercial (Licensed) – Training Data Lineage - A reference or link to the dataset(s) used for training, fine-tuning, and testing the model. – Data Sensitivity Profile - Classification of the <i>training data</i>, specifying if it contained PII, market-sensitive, confidential and strictly confidential, or other regulated information, even if the data was anonymized. – AI platform – Information on the underlying Technology environment (platform) used for AI lifecycle – Model Architecture & Framework - The specific algorithm type and the software framework/version used to build it – Performance Metrics & Bias Assessment - A link to documentation containing key performance metrics and the results of bias and fairness testing against relevant protected attributes. – Explainability (XAI) Method - The method used to explain the model's decisions, if applicable.
1.2	In addition to control requirements from ICT Asset Management, the dedicated or centralized asset inventory must further include, at a minimum, the following information for each AI System incl. General-purpose AI (GPAI) system: – AI Classification - The AI system's classification level, aligned with EU AI Act tiers and ID 5 of this Guideline: (Prohibited AI practices; High-risk AI systems; Systems with specific transparency obligations; Other AI systems). – AI Use-Case – reference or link to AI Use case which is basis for the AI System – AI platform – Information on the underlying Technology environment (platform) used for AI lifecycle – Intended Purpose & Prohibited Uses – A clear, unambiguous description of the specific business task the system is approved for, and a list of explicitly forbidden uses.

1.3

- Human Oversight Mechanism - The documented method by which humans oversee the system's operation. (Human-in-the-loop (approval), Human-on-the-loop (monitoring), Human-out-of-the-loop (post-incident review)).
- Failure Mode & Fallback Procedure - The documented procedure to follow if the AI System fails, malfunctions, provides unsafe output, or becomes unavailable.
- Operational Data Handling - Specifies the type and classification of *live, production data* being fed into the system and whether this data is logged or retained.
- Documented Capabilities & Modalities - A list of the system's inherent capabilities, such as Text Generation, Code Generation, Image Analysis, Data Analysis.
- Downstream Dependencies – A list of all linked AI Systems, AI Agents, or ICT Assets within DBG or third-party connectors that consume AI system (as a reverse dependency link).

In addition to control requirements from ICT Asset Management, the dedicated or centralized asset inventory must further include, at a minimum, the following information for each **AI Agent**:

- Agent Type & Sub-Type - The classification of the agent's nature and complexity. Must include a primary type (for example Interactive (Semi-Autonomous) or Autonomous) and a sub-type (e.g., Simple Reflex, Model-Based, Goal-Based, Utility-Based).
- Permitted Assets & Action Space - A precise, enumerated list of all Assets the AI Agent is authorized to use. This should also specify the data connectors and APIs, used
- Interfaces or linkage to other AI Agents or sub AI Agents connected
- Linked Account – Specifies the unique Identity of AI Agent or (user) account to which AI Agent is linked to (where applicable) or other/system account(s) that agent uses.
- DAC concept – Link to Digital Authorization Concept (DAC) to define Identity and Access Management (IAM)
- Reference or link to relevant up-to-date documentation from Material Change Process (MCP) as well as other used work processes for creation/management of AI Agents for example Individually Developed Agent (IDA).
- AI platform – Information on the underlying Technology environment (platform) used for AI lifecycle
- Trigger & Invocation Mechanism - The event or condition that activates the agent to perform its task (for example Time-based, Event-driven (API call), User-initiated...).
- Action Logging & Audit Trail - A location of the agent's action logs and audit trails
- Learning Mechanism - Specifies how the agent improves or changes its behavior (Static (No Learning), Supervised, Unsupervised, Reinforcement Learning...)
- Memory Type used – Information on ability to store and recall experiences and improve decisions (for example Short-term, long-term, Episodic, Semantic, Procedural).

1.4	– Agentic Framework - The specific underlying AI framework and version used to build and run the AI agent – Human Oversight Protocol - The explicit, documented procedure for human intervention. Must be linked and specify the type (e.g., Approval required, Real-time monitoring, Periodic review of actions). – Communication Channels & Input Surfaces - An inventory of all connectors through which the agent receives data or instructions (e.g. E-mail inbox, API endpoints, Slack channel, MS Teams, User-facing web form). Clear roles and responsibilities for management of each AI inventory must be defined and documented in respective procedures.
Protection goals Confidentiality, Integrity, Availability, Authenticity	Key references – Article 17 EU AI Act – ISO42001 A.9.3; ISO42001: A.6.2.6; ISO42001 7.4; ISO42001 A.9.2;
Start date of applicability: 2 Aug 2026	Relevant for role of DBG/LE as Provider, Deployer

ID: 2 (version 1.0)	AI Awareness and Literacy Program
2	A comprehensive and role-specific AI literacy program must be established, maintained, and continuously improved to ensure that all personnel involved in the AI system lifecycle possess the necessary competence, awareness, and understanding of AI-related risks, ethics, and operational responsibilities.
	Governance on educational program 2.1 An AI literacy/educational program must be established and documented. 2.2 The AI literacy/educational program must be reviewed periodically to ensure its continuing suitability, adequacy, and effectiveness 2.3 Roles and responsibilities related to AI literacy/education must be assigned, documented, and communicated across the organization. 2.4 The AI literacy/educational program must reference other relevant organizational policies and be available to interested parties, as appropriate. Competence and Qualification 2.5 The necessary competence for all personnel involved in the development of AI systems, AI Models and AI Agents must be determined and documented. 2.6 Actions to acquire necessary competence must be taken where applicable, and their effectiveness must be evaluated.

2.7	Security education for data scientists and development teams on AI threat awareness, including attacks on models, must be established.
	Awareness and Training
2.8	All engineers, including data scientists, should attend appropriate training before developing AI systems.
2.9	Awareness and Training processes must apply control requirements from “Human-related ICT Management Guideline”
2.10	The awareness on how to handle confidential data must be ensured, before an AI system is implemented.
2.11	Training programs should be tailored to roles and include topics such as AI fundamentals, ethical considerations, data privacy and security, model development, human-centered design, and AI system applications.
2.12	Training programs should be delivered through diverse formats such as online courses, workshops, and mentorship.
2.13	An approval process for training materials and procedures to ensure alignment with industry standards and regulatory requirements should be implemented.
2.14	AI Awareness activities and their effectiveness should be documented.
Protection goals Confidentiality, Integrity, Availability, Authenticity	Key references – Article 04 EU AI Act – DORA 2022/2554 A.13.6; DORA 2022/2554 A.5.4 – ISO 42001 A.2.2; ISO 42001 A.2.4; ISO 42001 A.3.2; ISO 42001 A.4.6; ISO42001 5.2; ISO42001 5.3; ISO42001 7.2; ISO42001 7.3; ISO23894 (A.3)
Start date of applicability: 2 Feb 2025	Relevant for role of DBG/LE as Provider, Deployer

ID: 3 (version 1.0)	Transparency and Information on AI Systems
3	AI systems must provide clear, accessible, and comprehensive information to enable deployers and users to understand, operate, and oversee the system responsibly, ensuring transparency, interpretability, and compliance with the EU AI Act and DBG frameworks.
	Responsible and acceptable use of AI systems
3.1	Objectives for the responsible use of AI systems must be identified and documented.
3.2	If acting as Provider, it must be ensured that documentation of High-risk AI systems is transparent on design and development activities and enable Deployers to interpret its output and appropriate use.

3.3	Processes and controls for acceptable use of AI systems must be defined, documented, and enforced.
	Instructions for Use of AI Systems
3.4	Instructions for use of AI Systems must be provided for each AI system, and must include: – Level of accuracy, including its metrics, robustness and other information as defined in ID 14 – The purpose of the AI system and explanation of its role – How to interact with the AI system. – The identity and contact details of the provider. – Technical requirements for high-risk AI systems – The characteristics, capabilities, and performance limitations (inc. but not limited to specific persons or groups). – any known or foreseeable circumstance, related to the use of the high-risk AI system which may lead to risks to health and safety or fundamental rights – technical capabilities of the high-risk AI system to provide information to explain and interpret its output – Pre-determined changes to the high-risk AI system and its performance identified during the initial conformity assessment (as defined in ID 18). – Human oversight measures. – Computational and hardware resources needed, – Expected system lifetime of the high-risk AI Systems, – A description of mechanisms for collecting, storing, and interpreting logs. – Potential benefits and harms from the impact assessment for high-risk AI Systems. – Updates, changes, and maintenance requirements.
3.5	If acting as Deployer, AI systems must be used in accordance with the provider's instructions for use. AI Model Documentation and Validation
3.6	Processes and procedures for validating AI model documentation must be defined, implemented, and evaluated.
3.7	When providing AI Models, baseline model documentation must be established and include: – Model description – example input/output – ownership – source information – creation date – evaluation data

	– version control – change log – training data schema.
3.7.1	When acting as Deployer it must be contractually ensured that Provider delivers baseline model documentation
	Technical measures for Transparency
3.8	It must be ensured that users are aware when they are interacting with an AI system.
3.8.1	AI System should include onboarding messages and help-page explanations.
3.8.2	As a provider, it must be ensured that AI System is designed so users are informed they're interacting with AI, for example by hard-coding visible AI disclosures into the User Interface and adding startup notices.
3.8.3	As a Deployer, the AI System must be tested before putting it into production if the information related to interacting with AI system is shown in the user interface.
3.9	It must be ensured that AI-Generated or AI-Manipulated Content is marked as such.
3.9.1	Any AI-generated or significantly altered content (text, audio, image, video) must be machine-readably marked and detectable as artificially generated.
3.9.2	User-visible notices that output is generated or assisted by AI must be added.
3.9.3	As a Provider, machine-readable watermarks or metadata must be embedded.
3.9.4	Deployers must be provided with instructions from Providers for preserving metadata across changes.
3.9.5	As a Deployer, metadata must not be removed when using provided AI Systems.
Protection goals Confidentiality, Integrity, Availability, Authenticity	Key references – Article 13 EU AI Act; Article 50 EU AI Act – DORA RTS RMF A8 – ISO42001: B.6.2.6; ISO 42001 A.8.2; ISO 42001 A.9.3; ISO 42001 A.6.2.7; ISO 42001 A.6.2.2, ISO 42001 A.6.2.6; – ISO23894 (A.12)
Start date of applicability: 2 Aug 2026	Relevant for role of DBG/LE as Provider, Deployer

ID: 4 (version 1.0)	Right to Explanation
4	It must be ensured that affected individuals, subject to a decision which is taken by the deployer based on the output from a high-risk AI system, receive clear and meaningful explanations regarding the role of high-risk AI systems in decisions that significantly impact them.
	Explainability and Interpretability
4.1	The need and required degree of explanation for the AI system must be established, documented, and communicated based on use-case criticality, audience, and regulatory context. The need and required degree for explanation of the AI system must be assessed and documented. A tailored explanation of why a particular output has been produced by the AI system must be provided to the users of high-risk AI system with an explanation method (Explainable AI). Persons subject to a decision which is taken by the deployer on the basis of the output from a high-risk AI System must be provided with explanations regarding the role of a high-risk AI system in decisions that produce legal effects or significantly affect them.
4.2	
4.3	
4.4	
Protection goals Confidentiality, Integrity, Availability, Authenticity	Key references – Article 86 EU AI Act – Article 22 GDPR – EDPB-EDPS, Joint Opinion 5/2021 on the proposal for a Regulation of the European Parliament and of the Council laying down harmonised rules on artificial intelligence (Artificial Intelligence Act); Section 72, p. 19.
Start date of applicability: 2 Aug 2026	Relevant for role of DBG/LE as Provider, Deployer

4.2 AI System Classification and Applicability

ID: 5 (version 1.0)	Classification of AI systems based on EU AI Act
5	All AI systems must be classified according to their AI risk level as defined by the EU AI Act, and AI-related risks must be managed as an integral part of the ICT Risk Management Framework through structured assessment, treatment, and documentation processes.
5.1	A documented procedure must be maintained to identify and classify AI systems in accordance with the EU AI Act, ensuring that such systems are subject to appropriate risk management, impact assessment, and regulatory compliance.
5.2	Each AI system must be classified into one of the following categories as per the EU AI Act: – Prohibited AI practices (Unacceptable risk) – High-risk AI systems – Systems with specific transparency obligations (Limited risk) – Other AI systems (Minimal risk) Prohibited AI Practices
5.3	It must be ensured that no AI systems developed, deployed, distributed, or operated employ prohibited practices as described in Chapter 5.1 to this Guideline High-Risk AI Systems
5.4	AI systems must be classified as high-risk if they fulfill any one of the following:
5.4.1	Are intended to be used as a safety component of a product or are themselves a product covered by the Union harmonization legislation.
5.4.2	Are subject to third-party conformity assessment under applicable Union harmonization legislation.
5.4.3	Are listed in high-risk areas such as biometrics, critical infrastructure, employment and workforce management, or other domains defined in Chapter 5.2 of this guideline.
5.4.4	Perform profiling of natural persons (see Chapter 5.2).
5.5	AI systems should not be classified as high-risk if they do not pose a significant risk to health, safety, or fundamental rights, including when:
5.5.1	Performing narrow procedural tasks.
5.5.2	Supporting previously completed human activities without influencing outcomes.
5.5.3	Detecting decision-making patterns without replacing human judgment.
5.5.4	Conducting preparatory tasks for assessments in high-risk domains.

5.6 5.6.1 5.6.2 5.6.3 5.7 5.8 5.9	Systems with specific transparency obligations The following systems must be classified at least as AI Systems with specific transparency obligations and must be subject to specific requirements as defined in control requirement ID7 (Systems with Specific Transparency Obligations): If AI systems are intended to directly interact with natural persons If AI systems, including general purpose AI systems, are generating synthetic audio, image, video or text content (incl. numbers) If AI system generates or manipulates images, audio or video content consisting of deep fake Other AI systems AI systems not classified as high-risk or subject to specific transparency obligations must still comply with applicable ICT Risk and DBG guidelines, ensuring adherence to principles of human oversight, fairness, non-discrimination, and secure lifecycle management. All control requirements listed in this guideline apply to these systems unless explicitly stated otherwise. Documentation and Traceability The classification decision and rationale for each AI system must be documented and retained throughout the AI system lifecycle in an inventory. Classification records must be made available to relevant stakeholders and authorities upon request.
Protection goals Confidentiality, Integrity, Availability, Authenticity	Key references – Article 05 EU AI Act; Article 06 EU AI Act; Article 50 EU AI Act; Annex I EU AI Act; Annex III EU AI Act – DORA 2022/2554 A8 – DORA RTS RMF A.4 – ISO42001 6.1.1; ISO42001 6.1.2; ISO42001 6.1.3; ISO42001 6.1.4;
Start date of applicability: 2 Feb 2025	Relevant for role of DBG/LE as Provider, Deployer

ID: 6 (version 1.0)	Classification of General-Purpose AI Models
6	General-purpose AI models must be classified based on their capabilities and impact, with specific thresholds and criteria determining whether they pose systemic risk, requiring enhanced regulatory oversight under the EU AI Act.
6.1 6.1.1	Classification Categories Each general-purpose AI model must be classified as one of the following: General-purpose AI model with systemic risk, if

6.1.2	– It demonstrates high-impact capabilities based on technical benchmarks and indicators or – It is designated by the European Commission, either ex officio or following a qualified alert from the scientific panel, based on the criteria for the designation of general-purpose AI models with systemic risk. General-purpose AI model with high-impact capabilities, if – the cumulative computation used for training exceeds 10^{25} floating point operations (FLOPs). Documentation and Reporting
6.2	Classification decisions on General-Purpose AI Models must be documented and retained throughout the AI system lifecycle in an inventory.
6.3	If acting as provider, a classification rationale and supporting evidence to the AI Office or market surveillance authorities must be prepared to be submitted upon their request.
Protection goals Confidentiality, Integrity, Availability, Authenticity	Key references – Article 51 EU AI Act, Annex XIII EU AI Act – DORA 2022/2554 A8 – DORA RTS RMF A.4
Start date of applicability: 2 Aug 2025	Relevant for role of DBG/LE as Provider, Deployer

ID: 7 (version 1.0)	Systems with Specific Transparency Obligations
7	AI systems subject to specific transparency obligations must clearly inform natural persons when interacting with AI, disclose synthetic content generation, and ensure compliance with disclosures made in a clear and timely manner.
	Interaction Disclosure 7.1 AI systems intended to directly interact with natural persons must be designed and developed to inform those individuals that they are interacting with an AI system. 7.2 This information must be provided clearly and at the latest at the time of the first interaction. 7.3 Transparency obligations for Systems with Specific Transparency obligations under and Article 13 of Directive (EU) 2016/680 must be fulfilled. Synthetic Content Identification 7.4 AI systems generating synthetic audio, image, video, or text content must ensure that outputs are:

7.4.1	Marked in a machine-readable format.
7.4.2	Detectable as artificially generated or manipulated.
7.5	AI-generated or AI-modified content must be appropriately labeled using suitable techniques (e.g., watermarking, metadata tagging)
	Deepfake Disclosure
7.6	If the AI system generates or manipulates deepfake content, it must disclose that the content has been artificially generated or manipulated.
7.7	Disclosure must be made clearly and at the time of exposure.
	Emotion Recognition and Biometric Categorization
7.8	It must be ensured that Emotion recognition systems and biometric categorization systems inform natural persons exposed to them of the AI system's operations.
7.9	Before putting emotion recognition systems and biometric categorization systems into production it must be ensured that these process personal data in accordance with applicable EU regulations (GDPR).
	Timing and Clarity of Information
7.10	All transparency-related information must be provided in a clear and understandable manner and at the latest at the time of first interaction or exposure.
Protection goals Confidentiality, Integrity, Availability, Authenticity	Key references – Article 50 EU AI Act – DORA 2022/2554 A8 – DORA RTS RMF A.4 – ISO23894 (A.12) – EDPB-EDPS, Joint Opinion 5/2021 on the proposal for a Regulation of the European Parliament and of the Council laying down harmonised rules on artificial intelligence (Artificial Intelligence Act); Section 60, p. 17.
Start date of applicability: 2 Aug 2026	Relevant for role of DBG/LE as Provider, Deployer

4.3 Risk Management and Oversight

ID: 8 (version 1.0)	AI Systems Risk Management
8	A comprehensive and lifecycle-wide risk management must be established for AI systems, ensuring identification, assessment, treatment, documentation, and monitoring of risks to health, safety, and fundamental rights, in alignment with ICT Risk Management Policy and Guideline as well as EU AI Act requirements.
	AI Risk management process 8.1 A comprehensive risk management process and procedure for AI systems and AI models must be established, implemented, documented, and maintained throughout their system lifecycle or the existing risk management processes and procedures used. 8.2 Processes and procedures for management of AI risks must align with the ICT Risk Management Policy and Guideline Specific AI Risk management requirements 8.3 Before concluding a contract with a third-party service provider, a risk assessment of the AI system must be carried out. 8.4 In the case of AI-specific subcontracting that supports critical or important functions (CIF), the documented analysis must be performed to define: – which third-parties are involved in data processing, – location/region where this takes place and – how long or complex chains of subcontracting may affect the process. 8.5 Besides control requirements from ICT Risk Management Guideline, specific risks posed by AI systems must be identified and assessed throughout their lifecycle. These include at least risks related to: 8.5.1 Health, safety, Fundamental rights 8.5.2 Data risks (e.g. Data security, integrity, privacy), 8.5.3 Model risks (e.g. Adversarial attacks, Prompt injections, Model interpretability, Supply chain attacks) 8.5.4 Operational risks (e.g. Lack of accountability, Security Vulnerabilities, model drift) 8.5.5 Ethical and legal risks (e.g. Bias, fairness, Lack of explainability, transparency, Intellectual property infringement) 8.5.6 Misinformation (Hallucinations) and manipulation 8.6 The behavior of the AI system for inputs that do not conform to specified requirements must be analyzed and documented using appropriate methods. 8.7 The risk assessment process for AI Systems, AI Models, AI Agents must include the evaluation of potential consequences for individuals, groups, and society. 8.8 The risk assessment of high-risk AI Systems must include data from post-market monitoring systems as defined in control requirement ID28 Post-Market Monitoring System.

Protection goals Confidentiality, Integrity, Availability, Authenticity	Key references – Article 09 EU AI Act, ISO 31000; ISO23894 CR – DORA 2022/2554 A.6; DORA 2022/2554 A.28; DORA 2022/2554 A.29; DORA 2022/2554 A.30 – ISO 42001 A.5.; ISO 42001 A.5.3; ISO 42001 A.5.4; ISO 42001 A.5.5; ISO 42001 6.1.1; ISO 42001 6.1.2; ISO 42001 6.1.3;
Start date of applicability: 2 Aug 2026	Relevant for role of DBG/LE as Provider, Deployer

ID: 9 (version 1.0)	Human Oversight of AI Systems
9	AI systems must be designed and operated with appropriate human oversight measures, based on criticality, that enable effective intervention, control, and/or accountability, minimizing risks to health, safety, and fundamental rights.
9.1	Processes and procedures to ensure human oversight and control of the AI system in compliance with regulatory requirements and organizational risk management must be established.
	Oversight Design and Implementation
9.2	The frequency, scope, and methods for security and robustness reviews of AI models in production must be documented.
9.3	High-Risk AI systems must be designed and developed to include appropriate human-machine interface tools that enable human intervention and control.
9.4	Critical decision points should be defined and integrated into AI related system workflows, where Human-In-The-Loop is needed,
9.5	Every Human-In-The-Loop decision, approval, or override must be logged with timestamps and user identifiers
9.6	The high-risk AI system must be monitored through human oversight throughout its lifecycle.
9.6.1	For AI systems with a classification lower than “high-risk,” the introduction of “human oversight” should be considered and, as part of the AI system's implementation, justified and documented whether human oversight is mandatory, optional, or not required.
	Override and Escalation Mechanisms
9.7	Procedures must be established to allow authorized personnel or users to override automated AI decisions.
9.8	Roles and responsibilities for human oversight should be defined and allocated according to organizational needs.
9.9	Procedures to override automated AI decisions should include: – Clear escalation paths;

	– Incident reporting systems; – Manual override buttons, – Fail-safe triggers.
9.10	Users must be informed of their ability to intervene or override the AI system when necessary.
9.11	If a potential risk to health or safety, or to fundamental rights, of persons is identified, use of the AI system must be suspended, and the provider must be informed.
	Worker and Individual Notification
9.12	Affected staff must be informed about the use of high-risk AI systems in the workplace, following applicable legal and DBG/LEs internal procedures.
9.13	Individuals subject to decisions made or assisted by an AI system must be informed of the system's use.
9.14	Each use of post-remote biometric identification must be documented, with records made accessible to market surveillance authorities.
9.15	Annual reports related to post-remote biometric identification (excluding sensitive operational data) must be submitted.
Protection goals Confidentiality, Integrity, Availability, Authenticity	Key references – Article 14 EU AI Act; Article 26 EU AI Act; Article 50 EU AI Act; – ISO 42001 A.3.2; ISO 42001 A.2.4; ISO27001 A.5.18; ISO27001 A.8.3; ISO27001 A.8.32; – Article 22 GDPR
Start date of applicability: 2 Aug 2026	Relevant for role of DBG/LE as Provider, Deployer

ID: 10 (version 1.0)	Fundamental Rights Impact Assessment for High-Risk AI Systems
10	Before deploying high-risk AI systems for public services, a Fundamental Rights Impact Assessment (FRIA) must be conducted and documented to evaluate potential impacts on individuals' fundamental rights. The results must be submitted to the market surveillance authority using the official template provided by the AI Office.
	Applicability 10.1 Fundamental Rights Impact Assessment FRIA must be conducted prior to the first use of a high-risk AI system when providing public services. AI systems listed under Chapter 5.2. point 2 (critical infrastructure) are exempt from FRIA obligations. Assessment Scope 10.2 The FRIA (for high-risk AI System) must include:

10.2.1	A description of the deployer's processes where the high-risk AI system will be used.
10.2.2	The timeframe and frequency of high-risk AI system use.
10.2.3	Categories of individuals or groups that are likely to be affected.
10.2.4	Specific risks of harm to those individuals or groups, based on provider information (see control requirement ID3 Transparency and Information on AI Systems).
10.2.5	Human oversight measures implemented.
10.2.6	Mitigation measures and internal governance arrangements, including complaint mechanisms.
	Methodology and Transparency
10.3	The FRIA process must include:
10.3.1	Risk identification: Analysis of potential impacts on fundamental rights (e.g., discrimination, personal data protection, freedom of expression).
10.3.2	Impact assessment: Evaluation of severity and likelihood of harm.
10.3.3	Mitigation planning: Definition of measures to reduce risks.
10.3.4	Documentation and transparency: Full record of the process and communication with affected individuals and authorities.
	Notification and Documentation
10.4	The results of the FRIA must be submitted to the market surveillance authority using the official template provided by the AI Office.
10.5	Previously conducted FRIAs or impact assessments by the provider should be reused if applicable.
	Reuse and Updates
10.6	The FRIA must be updated if any relevant factors change or become outdated during the system's lifecycle.
Protection goals Confidentiality, Integrity, Availability, Authenticity	Key references – Article 27, Article 26(9) EU AI Act, – Article 35 GDPR
Start date of applicability: 2 Aug 2026	Relevant for role of DBG/LE as Deployer

4.4 Technical and Operational Controls

ID: 11 (version 1.0)	AI Systems Data Governance
11	AI systems must be developed using training, validation, and testing datasets that meet defined quality standards and are subject to robust data governance practices, ensuring compliance with the EU AI Act, GDPR, and DBG Data Governance frameworks.
	Data Governance Framework and AI 11.1 Data governance and management practices must be applied to all training, validation, and testing datasets used in an AI system. In addition, where a high-risk AI system that involves the training, validation and testing of AI models, these must include documentation of: 11.1.1 Design choices 11.1.2 Data collection processes and data origin. 11.1.3 Data preparation and processing operations. 11.1.4 Formulated assumptions. 11.1.5 Assessment of data availability, quantity, and suitability. 11.1.6 Examination in view of possible biases 11.1.7 Appropriate measures to detect, prevent and mitigate possible biases 11.1.8 Identification of data gaps or shortcomings that prevent compliance. Data Quality and Integrity 11.2 Data quality controls must be implemented during the training of AI models to detect poisoned samples and anomalies using integrity checks, statistical deviation, or pattern recognition. 11.3 In addition to securing access to AI Model, secure data exchange between training data, AI model components, and end users must also be ensured. 11.4 Sensitive features in data used in AI Systems or AI Models must be identified, and potential biases against individuals or groups must be assessed and documented. 11.5 Measures to detect, prevent, and mitigate bias in AI Systems or AI Models must be implemented and documented. 11.6 If critical bias is detected, mitigation measures must be defined and implemented. Data Minimization and Privacy (AI Model training data) 11.7 Data that is not essential for the intended purpose must be removed or anonymized prior to AI model training. 11.8 Consistency should be ensured across training and test data in AI models, and independent datasets should be used when applicable.

11.09	Mechanisms must be in place to allow users and customers to stop processing their personal data for training, validation and testing of AI models. Data Segregation and Security
11.10	Confidential and strictly confidential development data (e.g., training/test data, AI model parameters, technical documentation) must be stored in segregated areas with restricted access.
11.11	Data used in training of AI Models that originate from different external sources must be segregated.
11.12	Security controls should be applied to protect data within AI models and AI systems, including checksums, encryption and signing mechanisms.
	Inference Locality and Confidentiality Processing
11.14	The data processing locality must be approved for an AI inference to be performed by AI Model Provider.
11.15	Before the first use of an AI Model it must be contractually defined how and if it's Provider may use DBG or legal entity's data for example to train its AI models or allow them to learn based on input patterns.
11.16	Use of AI Models must be limited to legal entity's authorized services.
Protection goals Confidentiality, Integrity, Availability, Authenticity	Key references – Article 10 EU AI Act, – DORA RTS RMF A.6; DORA RTS RMF A.14 – Article 5 GDPR – ISO 42001 A.5.2; ISO 42001 A.7.2; ISO 42001 A.7.3; ISO 42001 A.7.4; ISO 42001 A.4.2; ISO 42001 A.5.5; ISO 42001 A.6.1.3; ISO 42001 A.2.4; ISO 42001 A.5.4 ; ISO42001 2.2; ISO42001 5.2; ISO42001 7.5.3; ISO42001 6.3; ISO42001 7.5.3; – ISO23894 (A.4, A.6);
Start date of applicability: 2 Aug 2026	Relevant for role of DBG/LE as Provider

ID: 12 (version 1.0)	AI Systems Technical Documentation
12	Comprehensive technical documentation must be created and maintained for each AI system to demonstrate compliance with regulatory requirements, covering design, development, testing, risk management, performance, and lifecycle changes, and aligned with DBG's Software Development and ICT Change Management Guidelines.
	Documentation Scope and Structure
12.1	Technical documentation must be created and maintained for each AI System.

12.2	The scope and level of detail of the documentation should be determined based on the Classification of AI Systems after the EU AI Act (refer to Chapter 4.2.) and needs of relevant interested parties (e.g., users, partners, supervisory authorities).
12.3	A system description must be created and made available to users, including the intended purpose and relevant qualitative aspects.
	Mandatory Content Elements
12.4	The AI System technical documentation must include, at minimum:
12.4.1	A general description of the AI system.
12.4.2	A detailed description of system components incl. but not limited to AI Model and the development process.
12.4.3	Detailed information on monitoring, functioning, and control mechanisms.
12.4.4	For high-risk AI Systems, a description of performance metrics and their appropriateness.
12.4.5	A detailed description of the risk management process. If no specific process used, standard risk management documentation can be attached.
12.4.6	A record of relevant changes made to the system throughout its lifecycle.
12.4.7	For high-risk AI Systems, a list of harmonized standards applied (fully or partially).
12.4.8	For high-risk AI Systems, a copy of the EU declaration of conformity.
12.4.9	For high-risk AI Systems, a detailed description of the process in place to evaluate its performance in the post-market phase, including monitoring plan.
	Responsible Use and Governance
12.5	Objectives and processes for responsible use of AI systems must be identified, defined, and documented.
12.6	Guidelines and procedures for acceptable use of AI must be established, documented, and communicated to all relevant personnel.
12.7	Only approved AI Models and AI Systems must be used, with an updated list of authorized ones maintained.
	Technical documentation updates and change management
12.8	Technical documentation must be reviewed and updated regularly as well as after changes to the AI System, any of its components or when information relevant for its functionality changes incl performance, purpose, training data used.
Protection goals Confidentiality, Integrity, Availability, Authenticity	Key references – Article 11 EU AI Act; Annex IV EU AI Act – Article 5, 6, 13–14, 30, 32, 35, 36 GDPR – DORA RTS RMF A.15 – ISO 42001 A.3.2; ISO 42001 A.9.2; ISO 42001 A.9.3; – ISO23894 (6.7)
Start date of applicability: 2 Aug 2026	Relevant for role of DBG/LE as Provider, Deployer

ID: 13 (version 1.0)	AI Systems Events management and Logging
13	In addition to Control requirements from "Incident & Operational Event Management Guideline", for AI specific event records and logs must be maintained throughout their lifecycle to ensure traceability, accountability, and compliance with the EU AI Act, GDPR, and DBG's Guidelines.
	Logging Governance 13.1 Specific instructions for the AI related logging must be documented, where needed, including technical and organizational safeguards. 13.2 Externally sourced logs or monitoring data deemed necessary for AI system operation should be identified and controlled. 13.3 The logs for AI Systems must be kept for at least six months, unless provided otherwise in the applicable Union or national law (for example GDPR) and as part of the documentation kept under the relevant financial services law (DORA, CSSF, etc.) Logging and Traceability 13.4 Automatic recording of events (content and metadata logs) must be enabled and maintained for AI systems, enabling traceability of operation based on the instructions for use and post-market monitoring 13.5 Continuous real-time monitoring for anomalous behavior must be performed for high-risk AI systems and AI Systems supporting Critical Infrastructure and Critical or Important Functions (CIF). 13.6 The use of the AI system, including date, time, and user, must be logged to enable incident reconstruction and integration into existing incident detection processes. 13.7 Logging must be consistent across all components of the AI system and should be centralized where possible. 13.8 Logged data must be encrypted in transit and at rest, and existing data retention policies must be applied. 13.9 Actions carried out by the AI system must be uniquely identifiable to ensure authenticity. 13.10 The traceability of data used in the AI system must be ensured and documented. 13.11 Logs must be reviewed periodically and as needed, for example after major changes of AI Systems. 13.12 Usage reports, aligned with regulatory requirements and organizational standards, must be regularly generated. 13.13 The logging of AI decisions, model versions, and training data (to the extent permitted by data protection laws) must be enabled. 13.14 For AI systems that support critical or important functions (CIF), thresholds and indicators for misconduct must be defined.

13.15	Automatically generated logs of AI systems must be retained for at least six months or longer if required by law
13.16	Additional requirements for specific high-risk AI Systems For the (1) remote biometric identification systems, (2) AI systems intended to be used for biometric categorization and (3) intended to be used for emotion recognition logging capabilities the following must be provided: – recording of the period of each use of the system; – the reference database against which input data has been checked by the system; – the input data for which the search has led to a match; – the identification of the natural persons involved in the verification of the results
Protection goals Confidentiality, Integrity, Availability, Authenticity	Key references – Article 12, 19, 26 EU AI Act, – DORA 2022/2554 A.10.1,2; DORA 2022/2554 A.12 – GDPR
Start date of applicability: 2 Aug 2026	Relevant for role of DBG/LE as Provider, Deployer

ID: 14 (version 1.0)	Accuracy, Robustness, and Access to AI Systems
14	AI systems must maintain accuracy, robustness, consistency and access management throughout their lifecycle by implementing technical and organizational measures to prevent, detect, and mitigate AI-specific vulnerabilities, in alignment with ICT Risk Guidelines, EU AI Act, and DORA.
	Accuracy and Performance 14.1 Accuracy levels and relevant metrics must be declared in the instructions for use of AI systems. 14.2 Operational thresholds and safe fallback behavior should be defined and implemented for AI Systems 14.3 Uncertainty assessments of the AI system must be performed and documented to measure if components behave as intended. At least two areas should be covered: variability in the performance of the system, and uncertainty coming from insufficient knowledge. 14.4 Robustness of AI Systems against corner cases and boundary values must be assessed and documented. Impact Assessment

14.5	The frequency, scope, and methods for security and robustness reviews of AI models in production must be documented.
14.6	Impact analysis must be performed for each AI model to determine consequences of compromise.
14.7	Attack surfaces for white-box, gray-box, and black-box evasion or information extraction attacks must be assessed using appropriate vectors.
	Operational Resilience
14.8	A procedure must be in place to detect AI system failures.
14.9	In case of failure, the AI system must respond with error fallback functions.
14.10	AI systems should undergo regular review in terms of their resource requirements and performance to avoid capacity bottlenecks and ensure stable availability.
14.11	Automated monitoring procedures should be used to ensure the efficiency and scalability of the AI infrastructure.
14.12	AI models that are outdated or not used anymore should be removed or deactivated to prevent misuse.
	Role-Based Access and Separation of Duties
14.13	A Digital Authorization Concept (DAC) for the AI system must be created, defining roles, authorizations, and responsibilities.
14.14	Access to use or modify AI model output must be granted only to authorized users.
14.15	Roles authorized to modify AI-generated outputs must be defined.
14.16	All modifications to AI-generated output must be logged and reviewed regularly.
14.17	Segregation of duties (SoD) must be enforced to ensure that individuals modifying outputs are distinct from those authorizing and reviewing changes to AI Systems.
14.18	If AI generated outputs are modified, users must be notified and the changes must be clearly labeled.
14.19	Actions that the AI model can potentially trigger should be reduced to the minimum set of actions necessary for the AI use case.
14.20	Connections with existing IT Assets must be safeguarded with secure integrations at all AI system interfaces.
Protection goals Confidentiality, Integrity, Availability, Authenticity	Key references – Article 15 EU AI Act, ISO 27001, – DORA 2022/2554 A.9; DORA 2022/2554 A.10; DORA 2022/2554 A.12 – DORA RTS RMF A.9; DORA RTS RMF A.15; DORA RTS RMF A.16; DORA RTS RMF A.17.1,2; ; DORA RTS RMF A.21 – ISO 42001 A.6.1.2; ISO 42001 A.6.1.3; ISO 42001 A.6.2.2; ISO 42001 A.6.2.3; ISO 42001 A.6.2.4; ISO 42001 A.6.2.5; ISO 42001 A.6.2.6; ISO 42001 A.7.3; ISO 42001 A.7.4; ISO27001 A.8.3; ISO27001 A.8.11; – ISO23894 (A.9, A.11) – GDPR, in particular, Article 5(1)(d) and (f), 24, 25 and 32 thereof
Start date of applicability: 2 Aug 2026	Relevant for role of DBG/LE as Provider, Deployer

ID: 15 (version 1.0)	Secure AI System Development
15	Beside control requirements from “Software Development and ICT Change Management Guideline” AI systems must follow additional development practices throughout their lifecycle by implementing technical and organizational measures.
	Additional development practices for AI 15.1 Supply chain of training data and AI Models must be analyzed and the results documented and preserved. 15.2 If AI-assisted coding is used, additional source code analysis must be performed to detect unknown AI based functions. 15.2.1 AI-generated code must be explicitly marked. 15.2.2 Developers must document which AI tool generated the code and the prompts used (where feasible) 15.2.3 AI-generated code must not be merged without reviewer acknowledgement that the code contains AI-produced elements. 15.2.4 Unsupported, unknown, or risky libraries must not be imported without explicit approval. 15.2.5 Peer review by a senior developer must be performed on all AI generated code sections. 15.2.6 AI-generated code must not bypass mandatory quality gates and must be checked for hidden or unused functions and remote calls or external libraries. 15.2.7 The proportion of AI-generated code should be tracked and documented. 15.3 Continual validation during training of AI models must be performed including discrimination bias, drift measurement and the detection of staleness. 15.4 Integrity checks must be performed on training, test, and validation data, for self-developed AI Models. 15.5 Version control systems must be used for tracking changes to AI Models and AI Systems. 15.6 All AI Model versions and parameters must be archived to ensure reusability and traceability. 15.7 AI Systems must be tested before putting them into production, and regularly afterwards, to ensure they do not negatively influence the availability of IT Assets they interact with. 15.8 For emergency changes to AI systems, special approval and evaluation processes must be defined that enable changes to be implemented at short notice 15.9 Changes to the AI system should also be evaluated (e.g., retraining or adjustment of the model structure), even if all changes to the AI model are made by the third-party service provider. AI training process 15.10 For the AI training process, the following must be ensured:

15.10.1	Training and test data must come from trustworthy sources
15.10.2	(Open source) libraries and software packages used for training must not contain any known vulnerabilities.
15.10.3	The entire training process must be documented and versioned.
15.10.4	Process for Security analyses of training data must be established.
15.10.5	Security analyses must be performed to identify hidden manipulations within training data.
15.11	AI System Lifecycle Documentation should include: – Objectives for responsible development – Processes integrated into development lifecycle – Requirements and specifications of used Algorithms, Data and Parameters – Verification and validation measures – Deployment plans – Operational monitoring and support planned
Protection goals Confidentiality, Integrity, Availability, Authenticity	Key references – Article 15 EU AI Act, ISO 27001, – DORA 2022/2554 A.9; DORA 2022/2554 A.10; DORA 2022/2554 A.12 – DORA RTS RMF A.9; DORA RTS RMF A.15; DORA RTS RMF A.16; DORA RTS RMF A.17.1,2; ; DORA RTS RMF A.21 – ISO 42001 A.6.1.2; ISO 42001 A.6.1.3; ISO 42001 A.6.2.2; ISO 42001 A.6.2.3; ISO 42001 A.6.2.4; ISO 42001 A.6.2.5; ISO 42001 A.6.2.6; ISO 42001 A.7.3; ISO 42001 A.7.4; ISO27001 A.8.3; ISO27001 A.8.11; – ISO23894 (A.9, A.11) – Article 25 GDPR
Start date of applicability: 2 Aug 2026	Relevant for role of DBG/LE as Provider, Deployer

ID: 16 (version 1.0)	AI Threat, Incident and Vulnerability Management
16	AI systems must implement robust cybersecurity measures to prevent, detect, and respond to AI-specific threats, including adversarial manipulation and input/output tampering. Beyond control requirements from ICT Patch and Vulnerability Management Guideline further AI specific aspects must be considered.
	Threat Prevention and Detection

16.1	Appropriate technical measures must be implemented to prevent, detect, respond to, and control threats for AI systems such as: – Data poisoning (training set manipulation). – Model poisoning (pre-trained component manipulation). – Adversarial examples and model evasion. – Confidentiality attacks and model flaws. – Prompt injection / System Prompt Leakage – Input manipulation – Information extraction / Confidential data Disclosure – Model theft – Output integrity / Improper Output Handling – Vectors and embeddings vulnerabilities – Excessive Agency (functionality, permissions, autonomy) – Misinformation, Hallucinations, Overreliance – Unbounded Consumption – Anomalous behavior – Bias and Discrimination
16.2	AI specific intelligence sources should be included in the Threat Intelligence collection, with clear owners and regular updates.
16.3	For high-risk AI Systems, Threat Intelligence must be integrated in post-market monitoring in line with control requirement ID28 Post-Market monitoring System.
16.4	Potential risks from attack vectors on AI Systems in third-party hosted environments should be identified.
	Input Controls
16.5	Input validation and sanitization must be implemented to reject or correct malicious content for AI Systems.
16.6	Measures must be implemented to detect abnormal, invalid, or adversarial inputs to AI Systems.
16.7	Processes for validating, filtering, modifying, or blocking input must be defined and implemented across all AI lifecycle stages.
16.8	The security of third-party input validation processes must be assessed for AI Systems.
	Output Controls
16.9	Processes for validating, filtering, modifying, or blocking outputs must be defined and implemented across all AI lifecycle stages.
16.10	AI output limitations must be established.
16.11	The security of third-party output validation processes must be assessed for high-risk AI Systems.
16.12	AI Output that includes personal data must be detected and, where possible, blocked. If such output is determined to constitute a personal data breach, the appropriate DBG written rules must be applied (In particular, the Personal Data Breach Procedure).
16.13	It must be ensured that AI output does not violate copyright, trademark, or intellectual property rights.

	Incident management 16.14 Incident response procedures related to AI systems must be integrated into existing incident management processes. 16.15 AI incident categories and severity levels must be defined, and response procedures for each must be determined. 16.16 Escalation paths for suspicious or abnormal outputs must be defined and coordinated with providers of AI Systems. 16.17 Incidents that occur through or in connection with AI systems, that compromise the security of network and information systems and violate IT data protection objectives or have a negative impact on services provided must be recorded as ICT-related incident. 16.18 Incidents related to AI systems should also be labeled as AI related. Vulnerability scanning and Penetration testing 16.19 Vulnerability identification and evaluation measures must include security issues specific to AI Systems including Large Language Models (LLM), Retrieval-Augmented Generation (RAG) and Agentic AI. 16.20 AI specific Vulnerability Scanning and Assessments should include Threats listed in 16.1. of this Control Requirement and must be aligned with the fundamental test from “ICT Patch and Vulnerability Management Guideline” 16.21 Regular penetration testing of AI Systems must be conducted in line with “ICT Patch and Vulnerability Management Guideline” and the LLM treated as an untrusted user. 16.22 Adversarial Penetration Tests must be run to simulate AI specific attacks 16.23 Stress tests should be used to determine performance of AI Systems 16.24 Contractual agreements with the third-party regarding Penetration tests for AI Systems must include AI specific threats, procedures and scope. 16.25 All detected vulnerabilities related to high-risk AI Systems must be transferred and addressed to post-market monitoring in line with the control requirement ID28 Post-Market monitoring System.
Protection goals Confidentiality, Integrity, Availability, Authenticity	Key references – Article 15 EU AI Act, ISO 27001, – DORA 2022/2554 A.8; DORA 2022/2554 A.9; DORA 2022/2554 A.22; DORA 2022/2554 A.24; DORA 2022/2554 A.25 – ISO 42001 A.6.1.2; ISO 42001 A.6.1.3; ISO 42001 A.6.2.2; ISO 42001 A.6.2.3; ISO 42001 A.6.2.4; ISO 42001 A.6.2.5; ISO 42001 A.6.2.6; ISO 42001 A.7.3; ISO 42001 A.7.4; ISO27001 A.8.3; ISO27001 A.8.11; – ISO23894 (B.5, A.11) – GDPR, in particular, Article 4(12) in conjunction with 33 and 34 thereof.
Start date of applicability: 2 Aug 2026	Relevant for role of DBG/LE as Provider, Deployer

ID: 17 (version 1.0)	AI Agents Security and Boundaries
17	AI agents within AI systems must operate based on relevant established processes for Agentic AI within DBG, within clearly defined and consistently enforced security boundaries, tailored to roles, data confidentiality, and operational environments.
	AI Agents governance 17.1 Process for management of AI Agents through their lifecycle must be defined and established. 17.2 All AI Agents must be registered using established processes and minimum information entered in relevant inventory (see also ID 1 AI Resource and Asset Management) 17.3 AI platforms and production environments must be regularly scanned to discover unregistered AI Agents. Security boundaries for AI agents 17.4 Security boundaries for AI agents must be established based on role-based access, data-confidentiality and segregation Area (Red, Yellow, Blue and Green). 17.5 Boundary consistency must be maintained across environments, with identical rules, segregation, and hardening settings for AI Agents. 17.6 Boundaries and controls for AI Agents must be regularly reviewed and updated to reflect new threats, regulatory changes, and operational shifts. Identity & Access Management (IAM) 17.7 AI agents must be linked to unique, authenticated digital identities with human ownership. 17.8 Every AI Agent related activity must be bound to a unique AI identity to ensure traceability and accountability. 17.9 Delegated permissions should be used to tie AI agent actions to user context. 17.10 A Zero Trust Architecture must be implemented for AI Agents by forcing strict identity verification and access controls. 17.11 Need-to-know principles must be applied at every stage of AI Agent. 17.12 It must be ensured that control requirements from ICT Risk Identity & Access Management guideline apply. Data Governance & Protection 17.13 Access of AI agents to data must be based on data labels and managed by classification categories allowed for underlying AI platforms unless explicitly approved. 17.14 It must be ensured that all data accessed or processed by AI agents is encrypted both in transit and at rest.

	Monitoring & Logging 17.15 All AI agent actions, including data access, API calls, and user interactions must be logged 17.16 Logs must clearly distinguish between actions initiated autonomously by an AI Agent and those executed on behalf of a user. 17.17 Unusual AI agent behavior must be monitored to detect anomalies, such as accessing data outside its scope or performing unexpected actions. 17.18 Decisions from AI Agents must be regularly reviewed. Segregation of Environments 17.19 Environments must be segregated to isolate AI agent development and testing from production operations. 17.20 New AI agents must be tested in sandbox environments before deployment to production. Secure Tool & API Usage 17.21 AI agents must use only whitelisted Tools and APIs, independent of access rights of the AI Agent owner. 17.22 Unintended overload of IT assets must be prevented by controlling how frequently AI agents can call APIs. 17.23 User inputs must be validated and sanitized to prevent prompt injection attacks on AI Agents. Human supervision 17.25 All decisions by AI agents, that are changing data or executing actions, should be escalated to human user for approval. 17.26 For irreversible actions, the AI Agent must stop and get human approval before acting (Human-in-the-Loop (HITL)). 17.27 For reversible actions the AI Agent acts, but a human must be notified and can pause or roll back the action (Human-on-the-Line (HOTL)). 17.28 A global or per AI agent switch to immediately halt all "ReACT" loops and/or use of tools should be enabled (Emergency Off Switch). 17.29 Employees must be informed on how AI agent works, its limitations, and how to report suspicious behavior, before first use.
Protection goals Confidentiality, Integrity, Availability, Authenticity	Key references – Article 15 EU AI Act, ISO 27001, – ISO 42001 A.6.1.3; ISO 42001 A.6.2.3; – GDPR in particular, Article 5(1), 24, 25 and 32 thereof
Start date of applicability: 2 Aug 2026	Relevant for role of DBG/LE as Provider, Deployer

4.5 Compliance and Regulatory Alignment

ID: 18 (version 1.0)	Conformity assessment and Post-market monitoring for high-risk AI
18	Before placing a high-risk AI system in use, the appropriate conformity assessment procedure must be followed, either with internal controls or via a notified body, ensuring compliance with essential requirements through verification of the quality management system, technical documentation, and post-market monitoring processes.
18.1	Provider of high-risk AI System must establish the appropriate conformity assessment procedure ensuring compliance with requirements for high-risk AI systems from EU AI Act. Conformity assessment based on internal control (Annex VI EU AI Act)
18.2	Conformity assessment procedure based on internal control for the high-risk AI Systems must ensure that: – AI System technical documentation (control requirement ID 12) is up to date, – Compliance with all Requirements for high-risk AI Systems is regularly assessed and results documented.
18.3	The provider must verify that the design and development process of the high-risk AI system is consistent with the AI System technical documentation and document at least the following aspects: – risk management process used (control requirement ID 8), – implementation and maintenance of a post-market monitoring system (control requirement ID 28), – procedures related to the reporting of a serious incident (control requirement ID29) Conformity based on assessment involving a notified body (Annex VII EU AI Act)
18.4	Where applicable, the DBG or LE acting as provider of high-risk AI system must follow the conformity based on assessment involving a notified body, and create application which must include at least: – the name and address of the provider; – the list of AI systems covered; – the technical documentation for each AI system covered; – the documentation covering all related internal control aspects listed in Chapter 5.6. of this Guideline; – a written declaration that the same application has not been lodged with any other notified body
18.5	Records of the notified body's involvement and decisions must be retained and made available to competent authorities upon request.
Protection goals	Key references – Article 17, 72, 73, Annex VI & VII EU AI Act

Confidentiality, Integrity, Availability, Authenticity	
Start date of applicability: 2 Aug 2026	Relevant for role of DBG/LE as Provider

ID: 19 (version 1.0)	Documentation and Record-Keeping for high-risk AI
19	Documentation for high-risk AI systems must be securely stored and retained for at least 10 years after market placement or as required by relevant EU financial services laws. All records should be kept in a manner that ensures their integrity, confidentiality, and accessibility, in line with ICT Risk and DBG Guidelines.
19.1	The following documentation must be retained for a minimum of 10 years after the high-risk AI system is placed on the market or put into service, or in accordance with applicable Union financial services law (where higher): – Technical documentation (see control requirement ID 12 AI Systems Technical Documentation). – Documentation on internal control system for AI. – Notified body approvals (where applicable). – EU declarations of conformity (see control requirement ID 23 High-Risk AI Systems Conformity Assessment).
19.2	All conformity assessment activities, including internal checks and third-party evaluations, must be documented for high-risk AI system.
19.3	Records of high-risk AI systems must be retained in accordance with the ICT Risk and other relevant DBG Guidelines and made available for audit or regulatory review.
19.4	National competent authorities must be granted access to the retained documentation upon request.
19.5	Documentation of AI system must be stored in a secure and accessible format, ensuring integrity, confidentiality, and availability.
Protection goals Confidentiality, Integrity, Availability, Authenticity	Key references – Article 17, 18, 47 I EU AI Act – ISO23894 (6.7)
Start date of applicability: 2 Aug 2026	Relevant for role of DBG/LE as Provider

ID: 20 (version 1.0)	Corrective Actions for Non-Compliant high-risk AI systems
20	Corrective actions must be taken for non-compliant high-risk AI systems to ensure regulatory compliance, including bringing the system into conformity, disabling, withdrawing, or recalling it, and informing all relevant stakeholders.
20.1 20.2 20.3 20.4 20.5 20.6	Corrective Action Procedures For any high-risk AI system found to be non-compliant, the Provider must take one or more of the following corrective actions: – Bring the system into conformity with applicable requirements. – Disable the system to prevent further use. – Withdraw the system from the market. – Recall the system from users or deployers. Stakeholder Notification The Provider of high-risk AI system must inform Distributors and Deployers of the provided AI system of the non-compliance and the corrective actions taken by the Provider of a high-risk AI System. If the high-risk AI system is considered to be a Product presenting a risk (to the health or safety, or to fundamental rights, of persons), the Provider must investigate the causes and inform the market surveillance authorities competent for the high-risk AI system concerned. All corrective actions for high-risk AI systems must be documented, including: – The nature of non-compliance. – The decision-making process for selecting the corrective action. – The timeline and execution of the corrective measures. – Communication records with stakeholders and authorities. Integration with Incident Management Corrective actions should be integrated into the DBG incident detection and response processes, including AI-specific monitoring and escalation paths (see control requirement ID 13 AI Systems Events management and Logging). Logs and audit trails related to the AI incident and corrective actions must be retained and reviewed.
Protection goals Confidentiality, Integrity, Availability, Authenticity	Key references – Article 20 EU AI Act
Start date of applicability: 2 Aug 2026	Relevant for role of DBG/LE as Provider, Deployer

ID: 21 (version 1.0)	Importer / Distributor Due Diligence for High-Risk AI Systems
21	If acting as Importer and/or Distributor due diligence must be performed to ensure compliance with the EU AI Act before putting the AI Systems on the market or making them available.
	Importer Obligations 21.1 Importers must verify that high-risk AI systems comply with the EU AI Act before placing them on the market. 21.2 The following elements must be checked by Importers of high-risk AI systems: – Completion of the conformity assessment procedure (see control requirement ID 18 Conformity assessment and Post-market monitoring for high-risk AI) – Availability and completeness of technical documentation (see control requirement ID 12 AI Systems Technical Documentation). – Presence of CE marking and EU declaration of conformity. – Confirmation of authorized representation within the EU. 21.3 Where the high-risk AI system is considered to be a Product presenting a risk (to the health or safety, or to fundamental rights, of persons), the Importer must inform the Provider and the market surveillance authorities to that effect. Distributor Obligations 21.4 Distributors must ensure that high-risk AI systems made available on the market comply with the EU AI Act. 21.5 The following due diligence measures must be taken for high-risk AI system: – Verification of provider markings and identification. – Review of accompanying documentation and instructions for use. – Confirmation that the system is not subject to corrective actions or restrictions (see Control Requirement ID 20 Corrective Actions for Non-Compliant high-risk AI systems). 21.6 Where the high-risk AI system is considered to be a Product presenting a risk (to the health or safety, or to fundamental rights, of persons), the Distributor must inform the Provider or Importer, and the authorities competent for the high-risk AI system to that effect.
Protection goals Confidentiality, Integrity, Availability, Authenticity	Key references – Article 23, Article 24 EU AI Act
Start date of applicability: 2 Aug 2026	Relevant for role of DBG/LE as Provider, Deployer

ID: 22 (version 1.0)	Provider Responsibilities in Value Chain and Intellectual Property
22	Legal entities assuming provider responsibilities for high-risk AI systems through value chain activities, such as substantial modification, rebranding, or integration, must ensure full compliance with the Third-Party ICT Risk Management Guideline, EU AI Act, supported by written agreements with third-parties that respect intellectual property and confidentiality obligations.
	Provider Role Assumption 22.1 A legal entity within DBG must be declared as a Provider under the EU AI Act if: – It substantially modifies an existing AI system. – It repurposes a AI system into a high-risk AI system. – It places its name or trademark on a high-risk AI system. Third-party Agreements and Due Diligence 22.2 Responsibilities across the AI system lifecycle must be clearly allocated and documented between the LE, partners, customers, and third-party. 22.3 Before concluding the contract with third-party, it must be clarified in which formats AI training data, AI models, and metadata can be exported to remain operational in the event of failure or change of third-party. 22.4 Written agreements with third-party suppliers of AI components or services must ensure: – Delivery of necessary documentation and technical access to support compliance according to requirements from EU AI Act. – Alignment with this Guideline and other AI-relevant DBG's written rules. – Third-party accountability for corrective actions if components do not perform as intended or pose risks. Documentation and Integration 22.5 The integration of externally provided AI systems or components must be documented, including: – Source and nature of the component. – Security and performance assessments. – Impact analysis on individuals, groups, and society. 22.6 Any AI components/functions provided by a third-party for integration must have data governance frameworks, including those for the protection of personal data and structure/definitions on how it is collected, processed, stored 22.7 Any third-party supplier of AI system must document how they store their data and security frameworks around it, which may include personal data or IP of end-users. 22.8 Third-party must provide documentation of AI system with scope and level of details relevant for each category of interested parties, such as users, partners, supervisory and authorities. Risk and Attack Vector Analysis

22.9	If training data or AI models originate from the third-party, they must be analyzed for potential attack vectors, and the results of such analysis must be documented in the AI system's documentation.
Protection goals Confidentiality, Integrity, Availability, Authenticity	Key references – Article 25 EU AI Act – ISO 42001 A.10.3; – ISO23894 (A.2)
Start date of applicability: 2 Aug 2026	Relevant for role of DBG/LE as Provider, Deployer

ID: 23 (version 1.0)	High-Risk AI Systems Conformity Assessment
23	High-risk AI systems must undergo a conformity assessment before being placed on the market or put into service, ensuring compliance with the EU AI Act through internal control or notified body procedures, with documentation retained and accessible for regulatory oversight.
23.1	Assessment Procedure Selection The appropriate conformity assessment procedure must be followed before placing a high-risk AI system on the market or putting it into service. – For AI systems listed under points 2 to 8 of Chapter 5.2 of this Guideline, the internal control procedure (see control requirement ID 18 Conformity assessment and Post-market monitoring for high-risk AI), should be used. – For remote biometric identification, biometric categorization, and emotion recognition systems, assessment by a notified body must be conducted.
23.2	Substantial Modifications A new conformity assessment must be conducted if the high-risk AI system undergoes substantial modifications that affect compliance with essential requirements.
23.3	EU Declaration of Conformity A signed EU declaration of conformity must be drawn up for each high-risk AI system.
23.4	The EU declaration of conformity of a high-risk AI system must be retained for 10 years and provided to authorities upon request.
23.5	The EU declaration of conformity of high-risk AI system must include: 1. AI system name, type, and traceability reference. 2. Provider's name and address. 3. Statement of sole responsibility.

	4. Confirmation of conformity with the EU AI Act and other applicable EU laws. 5. Statement of compliance with GDPR, (if personal data is processed). 6. References to harmonised standards or common specifications. 7. Notified body details (if applicable), including certificate ID and procedure description. 8. Place and date of issue, name and function of the signatory, and their signature.
Protection goals Confidentiality, Integrity, Availability, Authenticity	Key references – Article 43, Article 47 EU AI Act, Annex V EU AI Act
Start date of applicability: 2 Aug 2026	Relevant for role of DBG/LE as Provider

ID: 24 (version 1.0)	High-Risk AI System Information for Registration
24	Detailed and up-to-date information about high-risk AI systems must be submitted to the EU database prior to market placement or deployment.
	Registration of High-Risk AI Systems 24.1 Prior to placing a high-risk AI system on the market, or putting it into service, provider must register itself and that system in the EU database for high-risk AI systems. 24.2 The information provided to the EU database must at least include information listed in Chapter 5.3.a of this guideline. 24.3 The information provided in the EU database must be kept up to date. Registration of Non-High-Risk AI Systems 24.4 Prior to placing a non-high-risk AI system on the market, or putting it into service, provider must register itself and that system in the EU database. 24.5 The information provided to the EU database must at least include information listed in Chapter 5.3.b of this guideline. 24.6 The information provided in the EU database must be kept up to date. Registration by Deployers 24.7 Prior to putting into service or using a high-risk AI system, deployers must register themselves, select the system and register its use in the EU database. The information provided to the EU database must at least include inputs listed in Chapter 5.3.c of this guideline 24.8 The information provided in the EU database must be kept up to date.

24.9 24.10 24.11	Misclassification Handling Corrective actions must be taken to ensure full compliance with the EU AI Act (see control requirement ID 20 Corrective Actions for Non-Compliant high-risk AI systems), if a system is misclassified as non-high-risk and market surveillance authorities conducted an evaluation. National-Level Registration High-risk AI systems listed under Chapter 5.2 to this Guideline, intended to be used as safety components in the management and operation of critical digital infrastructure, road traffic, or in the supply of water, gas, heating or electricity must be registered at the national level. Additional mitigation measures Even if a high-risk AI system complies with the AI Act, additional risk mitigation measures must be taken if required by national market surveillance authorities.
Protection goals Confidentiality, Integrity, Availability, Authenticity	Key references – Article 49, Article 71, Article 80, Article 82, EU AI Act, Annex III, Annex VIII EU AI Act
Start date of applicability: 2 Aug 2026	Relevant for role of DBG/LE as Provider, Deployer

ID: 25 (version 1.0)	Notification for General-Purpose AI with Systemic Risk
25	If a general-purpose AI model meets the criteria for systemic risk, the European Commission must be notified within two weeks, including supporting evidence and, if applicable, reasoned arguments for exemption. Designation by the Commission must be complied with, and reassessment may be requested after six months.
25.1 25.2	Mandatory Notification If a general-purpose AI model meets the criteria for systemic risk (see control requirement ID 6 Classification of General-Purpose AI Models), the provider must notify the European Commission within two weeks of identification. The notification to the European Commission must include: – Evidence demonstrating fulfillment of systemic risk criteria (see control requirement ID 6 Classification of General-Purpose AI Models and ID 26 Obligations as Providers of General-Purpose AI Models (incl. systemic risk)) – Technical documentation and performance benchmarks. – Impact indicators and computational metrics (e.g., FLOPs).

25.3 25.4 25.5 25.6 25.7	Reasoned Exemption Request If, based on internal analysis, the AI model does not pose actual systemic risk despite meeting the criteria, alongside the notification the explanation with reasoned arguments should be submitted as well. If the European Commission designates a model as systemic risk the provider must comply with the designation. Reassessment Procedure A reassessment of the systemic risk designation may be requested after six months, and the reassessment request must include: – Objective, detailed, and new evidence. – Updated performance and impact metrics. – Documentation of changes in deployment, safeguards, or model behavior. Documentation and Transparency All notifications, exemption requests, and reassessment submissions must be documented and retained. Information about the model's purpose, capabilities, limitations, and risks must be made available to users and authorities (see control requirement ID 3 Transparency and Information on AI Systems).
Protection goals Confidentiality, Integrity, Availability, Authenticity	Key references – Article 51 EU AI Act; Article 52 EU AI Act – ISO 42001 A.8.2; ISO 42001 A.9.3
Start date of applicability: 2 Aug 2025	Relevant for role of DBG/LE as Provider, Deployer

ID: 26 (version 1.0)	Obligations as Providers of General-Purpose AI Models (incl. systemic risk)
26	Providers of general-purpose AI models must maintain detailed technical documentation, share essential information with downstream providers, comply with copyright law, and publish a training data summary, in accordance with the EU AI Act and templates provided by the AI Office.
	Technical Documentation (Annex XI) 26.1 Technical documentation must be created and maintained for each general-purpose AI model and include information as listed in Chapter 5.7 Section 1 - Information to be provided by all providers of general-purpose AI models 26.2 For models with systemic risk, technical documentation must include additional details as listed in Chapter 5.7. Section 2 - Additional information to be provided by providers of general-purpose AI models with systemic risk Information for Downstream Providers (Annex XII) 26.3 Providers of general-purpose AI models (GPAI) must make available to downstream providers technical documentation to integrate the model into their AI system, as listed in Chapter 5.8 Transparency information for providers of general-purpose AI models to downstream providers Training Data Summary (AI Office Template) 26.4 A detailed public summary of the content used to train the AI model must be published using the official template provided by the AI Office. 26.5 The summary of the content used to train the AI model must include: – Main datasets and sources. – Data types and collection methods. – Notes on copyright-sensitive content and user-generated data. Code of Practice 26.6 The General-Purpose AI Code of Practice published by the AI Office or Commission should be used to demonstrate compliance with these obligations. 26.7 Requests from the Commission for documentation and information needed for assessing compliance must be responded to. AI models with systemic risk (additional control requirements) 26.8 Evaluation of general-purpose AI models with systemic risk must be conducted and documented in technical documentation using: – State-of-the-art protocols and tools. – Adversarial testing methodologies. – Alignment and robustness assessments. 26.9 Potential systemic risks at the Union level must be assessed for general-purpose AI models with systemic risk and include: – Model development.

26.10	– Market placement. – Use and integration. Risk mitigation strategies for general-purpose AI models with systemic risk must be implemented and documented, including: – Impact analysis. – Safeguards for unintended behavior. – Monitoring downstream use.
26.11	Serious incidents related to systemic-risk AI models must be: – Promptly reported to the AI Office and national authorities. – Documented with corrective actions taken.
Protection goals Confidentiality, Integrity, Availability, Authenticity	Key references – Article 53, Article 55, Article 91 Annex XI, Annex XII EU AI Act – ISO 42001 A.8.4; ISO 42001 A.8.5; ISO27001 A.5.25; ISO27002 A.5.26; ISO23894 (A.12, A.9)
Start date of applicability: 2 Aug 2025	Relevant for role of DBG/LE as Provider, Deployer

ID: 27 (version 1.0)	Real-World Testing of High-Risk AI Systems
27	Real-world testing of high-risk AI systems must be conducted under strict conditions, with informed consent, incident response protocols, and registration in the EU database, ensuring transparency, safety, and regulatory compliance.
	Testing Plan and Registration 27.1 Real-world testing of high-risk AI system must be conducted according to a detailed plan and under conditions specified in Chapter 5.4 of this guideline 27.2 Real-world testing of high-risk AI system must be registered in the EU database with the following information: (see Chapter 5.5 of this Guideline) – A Union-wide unique identification number. – Contact details of the provider and deployers involved. – A brief description of the AI system and its intended purpose. – A summary of the testing plan's main characteristics. – Information on any suspension or termination of the testing. 27.3 Real-world testing information must be kept up to date throughout the testing period of high-risk AI system. Informed Consent and Data Protection 27.4 Freely given, informed consent must be obtained from all subjects participating in the Real-world testing of high-risk AI system.

27.5	Subjects of Real-world testing of high-risk AI system must be informed of: – The purpose and conditions of the testing. – Their rights, including the right to withdraw at any time without detriment. – Data protection measures and the right to request deletion of personal data.
27.6	Data in Real-world testing of high-risk AI system must be anonymized or removed when no longer needed.
	Incident Management
27.7	Any serious incident during Real-world testing of high-risk AI system must be: – Reported immediately to the national market surveillance authority, in line with Control Requirement ID 28 Serious Incident Reporting Procedure – Mitigated promptly, with testing suspended until resolved or terminated. – Documented, including corrective actions and communication to affected users.
27.8	A procedure for prompt recall of the AI system must be established in case of termination.
	Cybersecurity and Data Integrity
27.9	Confidential training data should be obfuscated using available techniques (such as encryption, masking, or anonymization) during testing of high-risk AI system.
Protection goals Confidentiality, Integrity, Availability, Authenticity	Key references – Article 60, Article 61, Article 73, Article 76, Annex III, Annex IX EU AI Act – ISO 42001 A.6.2.8; ISO 27001 A.5.37;
Start date of applicability: 2 Aug 2025	Relevant for role of DBG/LE as Provider, Deployer

ID: 28 (version 1.0)	Serious Incident Reporting Procedure
28	A formal procedure must be established for reporting serious incidents related to high-risk AI systems to market surveillance authorities and, where applicable, notified bodies, ensuring timely notification, investigation, and corrective action in compliance with the EU AI Act.
28.1	Definition and Scope A serious incident must be reported if it results in: – Death or serious damage to health. – Significant material or immaterial damage. – A suspected causal relationship between the AI system and the incident.

28.2	For ICT-related AI Incidents to be reported under DORA, the requirements of ITS 2025/302, which describes standard forms, templates and procedures for reporting major ICT-related Incidents, must be followed.
	Reporting Timeline
28.3	The serious incident related to AI system must be reported: – In the event of widespread infringement or a serious incident, immediately, or not later than two days after the Provider or, where applicable, the Deployer becomes aware of in the event – In the event of the death of a person, immediately, but not later than 10 days, after the Provider or the Deployer has established, or as soon as it suspects, a causal relationship between the high-risk AI system and the serious incident or becomes aware of the serious incident – In other incidents, immediately, or no later than 15 days after the Provider or Deployer becomes aware of the incident or suspects a causal link between the AI system and the serious incident or the reasonable likelihood of it.
	Reporting Channels
28.4	Reports on serious incidents related to AI systems must be submitted to: – The provider of AI System – The national market surveillance authority. – The notified body (if applicable).
	Investigation and Corrective Action
28.5	Following a serious incident report on AI system, the following actions must be performed: – Conduct a risk assessment and root cause analysis. – Implement corrective actions. – Cooperate fully with authorities and notified bodies. – Avoid unauthorized alterations to the AI system before informing authorities.
	Incident Response Procedures
28.6	Formal serious incident response procedures for AI systems must be implemented and documented. Existing incident procedures should be leveraged or updated.
28.7	Serious incident response procedures for AI systems must be in line with ICT Incident & Operational Event Management Guideline.
28.8	The serious incident reporting procedure must cover the entire lifecycle of the AI system, including post-market monitoring (see control requirement ID 28 Post-Market Monitoring System).
28.9	Impacted individuals of serious incident related to AI System must be allowed to submit claims and complaints and their feedback should be regularly reviewed.
Protection goals Confidentiality, Integrity, Availability, Authenticity	Key references – Article 73 EU AI Act – DORA 2022/2554 A 19 – DORA RTS Major Incident Reporting

Start date of applicability: 2 Aug 2026	Relevant for role of DBG/LE as Provider, Deployer
---	---

ID: 29 (version 1.0)	Post-Market Monitoring System
29	A proportionate post-market monitoring system must be established and maintained for high-risk AI systems to ensure continuous compliance with the EU AI Act and internal control requirements, through structured data collection, performance analysis, and corrective action mechanisms.
	System Establishment and Scope 29.1 A post-market monitoring system must be established and maintained for each high-risk AI system. 29.2 The post-market monitoring system must be proportionate to the nature, risks, and complexity of the AI system and should be integrated into existing systems, provided equivalent protection is ensured. Monitoring Plan and Documentation 29.3 The monitoring system must be based on a documented plan included in the technical documentation of high-risk AI system (see control requirement ID 12 AI Systems Technical Documentation) and must specify: – Data sources and types. – Collection methods and frequency. – Analysis procedures and performance metrics. – Corrective action mechanisms and escalation paths. Performance Monitoring 29.4 The performance of the AI system must be continuously monitored and documented using defined Key Performance Indicators (KPIs). 29.5 Performance requirements and KPIs should be included in the system description. 29.6 Deviations from defined performance thresholds of AI system must be made transparent and addressed. Data Collection and Analysis 29.7 The Post-Market Monitoring System for AI system must actively collect, document, and analyze: – Operational data from the AI system. – Feedback and usage data from deployers. – Interactions with other AI systems throughout the lifecycle.

Protection goals Confidentiality, Integrity, Availability, Authenticity	Key references – Article 72 EU AI Act – DORA 2022/2554 A 19 – DORA RTS Major Incident Reporting
Start date of applicability: 2 Aug 2026	Relevant for role of DBG/LE as Provider, Deployer

ID: 30 (version 1.0)	Market Surveillance authorities and Non-Compliance
30	The full cooperation with market surveillance authorities must be ensured by providing access to documentation, data, and other relevant artifacts necessary. Corrective actions must be implemented when notified of non-compliance in high-risk AI systems by market surveillance authorities.
30.1	Market surveillance authorities (relevant financial supervisory authority or another relevant authority as identified by the Member State) must be granted full access to the documentation as well as the training, validation and testing data sets used for the development of high-risk AI systems
30.2	Market surveillance authorities must be cooperated with, and they must be provided with necessary information, documentation, data sets, and source code (under specific conditions) to facilitate their assessment of high-risk AI systems.
30.3	As an Operator, corrective action must be taken when national market surveillance authorities identify and report risks related to high-risk AI systems, including its withdrawal or recall if necessary.
30.4	All appropriate corrective actions must be taken to bring the AI system into compliance: – to withdraw the AI system from the market, or – to recall it within a period the market surveillance authority may prescribe
30.5	Corrective actions must be implemented across the Legal Entities in EU market when notified by a market surveillance authority about non-compliant high-risk AI within the timeline prescribed.
Protection goals Confidentiality, Integrity, Availability, Authenticity	Key references – Article 74 EU AI Act, Article 79 EU AI Act, Article 80 EU AI Act, Article 82 EU AI Act – ISO23894 (6.5.2)
Start date of applicability: 2 Aug 2026	Relevant for role of DBG/LE as Provider, Deployer

5 Specifications of requirements

5.1 Prohibited AI practices

ID: 5.3 (version 1.0)	The following AI practices must be prohibited (Article 5 EU AI Act)
5.3.1	Intended to use subliminal techniques outside of a person's awareness to influence a person's behavior or purposefully manipulative or deceptive techniques, with the effect of materially distorting behavior or appreciably impairing decision-making and causing or be reasonably likely to cause significant harm;
5.3.2	Intended to exploit any of the vulnerabilities of a person or a specific group of persons due to their age, disability or a specific social or economic situation, with the objective to or the effect of materially distorting the behavior of that person or a person pertaining to that group in a manner that causes or is reasonably likely to cause that person or another person significant harm
5.3.3	Biometric categorization system that categorizes natural persons according to sensitive or protected attributes or characteristics or based on the inference of those attributes or characteristics;
5.3.4	Intended to be used for social scoring evaluation or classification of the trustworthiness of individuals over time natural persons or groups thereof based on their social behavior or known, inferred, or predicted personality characteristics which may lead to a detrimental or unfavorable treatment either unrelated (to the data generation/collection context) or unjustified/disproportionate (to the social behavior);of such persons or groups thereof
5.3.5	Intended to be used for real-time biometric recognition in publicly accessible spaces for purposes of law enforcement.
5.3.6	To be used for risk assessments of natural persons or groups thereof to assess the risk of a natural person for offending or reoffending or for predicting the occurrence or reoccurrence of an actual or potential criminal or administrative offence based on profiling of a natural person or on assessing personality traits and characteristics;
5.3.7	To be used to create or expand facial recognition databases through the untargeted scraping of facial images from the internet or CCTV footage
5.3.8	To be used to infer emotions of a natural person in the workplace or education institutions.

5.2 High-risk AI systems

ID: 5.4 (version 1.0)	High-risk AI systems are the AI systems listed in any of the following areas (based on Article 6 (2) EU AI Act; ANNEX III):
5.4.4.1	Biometrics, in so far as their use is permitted under relevant Union or national law: a) remote biometric identification systems. b) This should not include AI systems intended to be used for biometric verification the sole purpose of which is to confirm that a specific natural person is the person he or she claims to be; c) AI systems intended to be used for biometric categorization, according to sensitive or protected attributes or characteristics based on the inference of those attributes or characteristics d) AI systems intended to be used for emotion recognition.
5.4.4.2	Critical infrastructure: AI systems intended to be used as safety components in the management and operation of critical digital infrastructure, road traffic, or in the supply of water, gas, heating or electricity.
5.4.4.3	Education and vocational training: a) AI systems intended to be used to determine access or admission or to assign natural persons to educational and vocational training institutions at all levels; b) AI systems intended to be used to evaluate learning outcomes, including when those outcomes are used to steer the learning process of natural persons in educational and vocational training institutions at all levels; c) AI systems intended to be used for the purpose of assessing the appropriate level of education that an individual will receive or will be able to access, in the context of or within educational and vocational training institutions at all levels; d) AI systems intended to be used for monitoring and detecting prohibited behavior of students during tests in the context of or within educational and vocational training institutions at all levels.
5.4.4.4	Employment, workers' management and access to self-employment: a) AI systems intended to be used for the recruitment or selection of natural persons, in particular to place targeted job advertisements, to analyze and filter job applications, and to evaluate candidates; b) AI systems intended to be used to make decisions affecting terms of work-related relationships, the promotion or termination of work-related contractual relationships, to allocate tasks based on individual behavior or personal traits or characteristics or to monitor and evaluate the performance and behavior of persons in such relationships.
5.4.4.5	Access to and enjoyment of essential private services and essential public services and benefits: a) AI systems intended to be used by public authorities or on behalf of public authorities to evaluate the eligibility of natural persons for essential public

	assistance benefits and services, including healthcare services, as well as to grant, reduce, revoke, or reclaim such benefits and services; b) AI systems intended to be used to evaluate the creditworthiness of natural persons or establish their credit score, with the exception of AI systems used for the purpose of detecting financial fraud; c) AI systems intended to be used for risk assessment and pricing in relation to natural persons in the case of life and health insurance; d) AI systems intended to evaluate and classify emergency calls by natural persons or to be used to dispatch, or to establish priority in the dispatching of, emergency first response services, including by police, firefighters and medical aid, as well as of emergency healthcare patient triage systems.
5.4.4.6	Law enforcement, in so far as their use is permitted under relevant Union or national law: a) AI systems intended to be used by or on behalf of law enforcement authorities, or by Union institutions, bodies, offices or agencies in support of law enforcement authorities or on their behalf to assess the risk of a natural person becoming the victim of criminal offences; b) AI systems intended to be used by or on behalf of law enforcement authorities or by Union institutions, bodies, offices or agencies in support of law enforcement authorities as polygraphs or similar tools; c) AI systems intended to be used by or on behalf of law enforcement authorities, or by Union institutions, bodies, offices or agencies, in support of law enforcement authorities to evaluate the reliability of evidence in the course of the investigation or prosecution of criminal offences; d) AI systems intended to be used by law enforcement authorities or on their behalf or by Union institutions, bodies, offices or agencies in support of law enforcement authorities for assessing the risk of a natural person offending or re-offending not solely on the basis of the profiling of natural persons as referred to in Article 3(4) of Directive (EU) 2016/680, or to assess personality traits and characteristics or past criminal behavior of natural persons or groups; e) AI systems intended to be used by or on behalf of law enforcement authorities or by Union institutions, bodies, offices or agencies in support of law enforcement authorities for the profiling of natural persons as referred to in Article 3(4) of Directive (EU) 2016/680 in the course of the detection, investigation or prosecution of criminal offences.
5.4.4.7	Migration, asylum and border control management, in so far as their use is permitted under relevant Union or national law: a) AI systems intended to be used by or on behalf of competent public authorities or by Union institutions, bodies, offices or agencies as polygraphs or similar tools; b) AI systems intended to be used by or on behalf of competent public authorities or by Union institutions, bodies, offices or agencies to assess a risk, including a security risk, a risk of irregular migration, or a health risk, posed by a natural person who intends to enter or who has entered into the territory of a Member State; c) AI systems intended to be used by or on behalf of competent public authorities or by Union institutions, bodies, offices or agencies to assist

5.4.4.8	competent public authorities for the examination of applications for asylum, visa or residence permits and for associated complaints with regard to the eligibility of the natural persons applying for a status, including related assessments of the reliability of evidence; d) AI systems intended to be used by or on behalf of competent public authorities, or by Union institutions, bodies, offices or agencies, in the context of migration, asylum or border control management, for the purpose of detecting, recognizing or identifying natural persons, with the exception of the verification of travel documents. Administration of justice and democratic processes: a) AI systems intended to be used by a judicial authority or on their behalf to assist a judicial authority in researching and interpreting facts and the law and in applying the law to a concrete set of facts, or to be used in a similar way in alternative dispute resolution; b) AI systems intended to be used for influencing the outcome of an election or referendum or the voting behavior of natural persons in the exercise of their vote in elections or referenda. This does not include AI systems to the output of which natural persons are not directly exposed, such as tools used to organize, optimize or structure political campaigns from an administrative or logistical point of view.
---------	--

5.3 Information to be submitted upon the registration of high-risk AI

ID: 24.2-24.7 (version 1.0)	Information to be submitted upon the registration of high-risk AI systems in accordance with Article 49 and Annex VIII EU AI Act
24.2.1	a) The following information must be submitted by providers to the EU database prior to placing a high-risk AI system on the market: 1. Provider's name, address, and contact details. 2. Contact details of any person submitting information on behalf of the provider. 3. Authorized representative's contact details (if applicable). 4. AI system trade name and traceability reference. 5. Description of the intended purpose and supported components/functions. 6. Concise description of data used and operating logic. 7. System status (e.g., on market, recalled). 8. Certificate details from notified body (type, number, expiry date, body ID). 9. Scanned copy of the certificate (if applicable). 10. Member States where the system is placed on the market or in service. 11. Copy of the EU declaration of conformity (see control requirement ID 23 High-Risk AI Systems Conformity Assessment). 12. Electronic instructions for use 13. 13. Optional URL for additional information.
24.5.1	b) The following information must be submitted by providers to the EU database prior to placing a non-high-risk AI system on the market: 1. Provider's contact details. 2. Contact details of any person submitting on behalf of the provider.

24.7.1	3. Authorized representative's contact details (if applicable). 4. AI system trade name and traceability reference. 5. Intended purpose of the system. 6. Conditions under Article 6(3) EU AI Act justifying non-high-risk classification. 7. Summary of rationale for non-high-risk classification. 8. System status. 9. Member States where the system is placed on the market or in service. c) The following information must be submitted by deployers to the EU database prior to using a high-risk AI system: 1. Deployer's name, address, and contact details. 2. Contact details of any person submitting on behalf of the deployer. 3. URL of the AI system's entry in the EU database. 4. Summary of the Fundamental Rights Impact Assessment (FRIA) 5. Summary of the Data Protection Impact Assessment (DPIA), if applicable.
--------	---

5.4 Testing of high-risk AI systems in real world conditions

ID: 27.1 (version 1.0)	For the testing of high-risk AI systems in real world conditions outside AI regulatory sandboxes all the following conditions must be met according to Article 60 (4) EU AI Act
27.1.1	Testing Plan of high-risk AI system – A real-world testing plan must be prepared and submitted to the competent market surveillance authority in the Member State where testing will occur.
27.1.2	Approval of high-risk AI system – Approval from the market surveillance authority must be obtained before testing begins. Where tacit approval is permitted under national law, testing must not commence until the approval period has elapsed.
27.1.3	Registration of high-risk AI system – Testing in real-world conditions must be registered with a unique Union-wide identification number and include all information specified in Annex IX EU AI Act. – For AI systems in sensitive areas (law enforcement, migration, asylum, border control), registration must be completed in the secure non-public EU database as required by Article 49 EU AI Act.
27.1.4	Legal Representation related to high-risk AI system – The provider or prospective provider must be established in the Union or must appoint a legal representative established in the Union.
27.1.5	Data Transfer and Protection (high-risk AI system) – Data collected during testing must not be transferred to third countries unless appropriate safeguards under Union law are implemented. – Personal data of test subjects must be deleted after testing is completed.

27.1.6	Duration of Testing of high-risk AI system – Testing must not exceed six months, with a possible extension of six months subject to prior notification and justification to the market surveillance authority.
27.1.7	Protection of Vulnerable Groups (high-risk AI system) – The subjects of the testing in real world conditions who are persons belonging to vulnerable groups due to their age or disability, are appropriately protected
27.1.8	Cooperation with Deployers of high-risk AI system – Where testing is organized with Deployers, all relevant aspects must be communicated to them, and instructions for use must be provided. – A formal agreement specifying roles and responsibilities must be concluded to ensure compliance with EU and national law.
27.1.9	Informed Consent (high-risk AI system) – the subjects of the testing in real world conditions have given informed consent – personal data of the subjects must be deleted after the test is performed
27.1.10	Oversight and Competence (high-risk AI system) – The testing in real world conditions must be effectively overseen by the Provider. – Deployers participating in testing must also ensure oversight through competent individuals.
27.1.11	Reversibility of AI Outputs (high-risk AI system) – Predictions, recommendations, or decisions generated by the AI system during testing must be capable of being reversed and disregarded.

5.5 Information to be submitted upon the registration of high-risk AI systems

ID: 27.2 (version 1.0)	According to Annex IX EU AI Act, the following information must be provided and thereafter kept up to date regarding testing of high-risk AI systems in real-world conditions to be registered in accordance with Article 60 EU AI Act:
27.2.1	According to Annex IX EU AI Act, the following information must be provided and thereafter kept up to date regarding testing of high-risk AI systems in real-world conditions to be registered in accordance with Article 60 EU AI Act: 1. A Union-wide unique single identification number of the testing in real world conditions; 2. The name and contact details of the provider or prospective provider and of the deployers involved in the testing in real world conditions; 3. A brief description of the AI system, its intended purpose, and other information necessary for the identification of the system; 4. A summary of the main characteristics of the plan for testing in real world conditions; 5. Information on the suspension or termination of the testing in real world conditions.

5.6 Conformity based on an assessment

ID: 18.4 (version 1.0)	These requirements (according to Annex VII EU AI Act) apply to high-risk AI systems that undergo a conformity assessment based on a quality management system and technical documentation review by a notified body.
18.4.1.1	An approved internal control system for AI for the design, development, and testing of high-risk AI systems must be established, examined, and maintained in accordance with regulatory requirements.
18.4.1.2	The technical documentation for each high-risk AI system must be compiled and examined for conformity by a notified body.
18.4.2.1	A complete set of documentation for the internal control system for AI (AI ICS) must be created and maintained. This documentation must include: – The name and address of the provider and any authorized representatives. – A definitive list of all AI systems covered by the AI ICS. – The complete technical documentation for each listed AI system. – Detailed documentation of the AI ICS, covering all aspects required by Article 17 of the EU AI Act. – A description of the procedures in place to ensure the AI ICS remains adequate and effective. – A written declaration confirming that the same application has not been lodged with another notified body.
18.4.2.2	The approved AI ICS must be continuously implemented and maintained to ensure its adequacy and effectiveness.
18.4.2.3	Any intended changes to the approved AI ICS or the list of AI systems it covers must be identified, documented, and communicated to the relevant notified body for assessment.
18.4.2.4	All assessment decisions, conclusions, and notifications from the notified body regarding the AI ICS must be formally recorded and archived.
18.4.3.1	The complete technical documentation as specified in Control Requirement ID 12 AI Systems Technical Documentation must be prepared and maintained for assessment by a notified body.
18.4.3.2	Secure access to training, validation, and testing datasets must be provided to the notified body upon request for the purpose of conformity assessment. This may include providing access through APIs or other remote access tools.
18.4.3.3	Secure access to the training and trained models of the AI system, including relevant parameters, must be provided to the notified body upon a reasoned request, subject to existing laws on the protection of intellectual property and trade secrets.

18.4.3.4	A process must be in place to provide further evidence or conduct additional tests as required by the notified body to assess conformity.
18.4.3.5	All Union technical documentation assessment certificates issued by a notified body must be formally recorded and managed, including any specified conditions for their validity.
18.4.3.6	In case of non-conformity, the detailed reasons for the refusal to issue a certificate must be recorded and analyzed. Required corrective actions, such as the re-training of the AI system, must be undertaken before a new assessment is sought.
18.4.3.7	Any change to the AI system that could affect its compliance with requirements, or its intended purpose must be documented and formally communicated to the notified body that issued the certificate for further assessment.
18.4.4.1	It must be ensured that the terms and conditions of the approved AI ICS are duly complied with.
18.4.4.2	For surveillance purposes, access to premises where the design, development, and testing of AI systems occur, along with all necessary information, must be granted to the notified body.
18.4.4.3	Periodic audit reports from the notified body must be received and reviewed. Any findings or required actions must be addressed and documented.

5.7 Technical documentation for providers of general-purpose AI models

ID: 26.1 (version 1.0)	Section 1 - Information to be provided by all providers of general-purpose AI models (Annex XI EU AI Act)
26.1.1	A general description of the general-purpose AI model including: a) the tasks that the model is intended to perform and the type and nature of AI systems in which it can be integrated; b) the acceptable use policies applicable; c) the date of release and methods of distribution; d) the architecture and number of parameters; e) the modality (e.g. text, image) and format of inputs and outputs; f) the license.
26.1.2	A detailed description of the elements of the model referred to in point 1, and relevant information of the process for the development, including the following elements: a) the technical means (e.g. instructions of use, infrastructure, tools) required for the general-purpose AI model to be integrated in AI systems; b) the design specifications of the model and training process, including training methodologies and techniques, the key design choices including the rationale and assumptions made; what the model is designed to optimize for and the relevance of the different parameters, as applicable;

	c) information on the data used for training, testing and validation, where applicable, including the type and provenance of data and curation methodologies (e.g. cleaning, filtering, etc.), the number of data points, their scope and main characteristics; how the data was obtained and selected as well as all other measures to detect the unsuitability of data sources and methods to detect identifiable biases, where applicable; d) the computational resources used to train the model (e.g. number of floating point operations), training time, and other relevant details related to the training; e) known or estimated energy consumption of the model. Where the energy consumption of the model is unknown, the energy consumption may be based on information about computational resources used.
--	---

ID: 26.2 (version 1.0)	Section 2 - Additional information to be provided by providers of general-purpose AI models with systemic risk (Annex XI EU AI Act)
26.2.1	A detailed description of the evaluation strategies, including evaluation results, on the basis of available public evaluation protocols and tools or otherwise of other evaluation methodologies. Evaluation strategies must include evaluation criteria, metrics and the methodology on the identification of limitations.
26.2.2	Where applicable, a detailed description of the measures put in place for the purpose of conducting internal and/or external adversarial testing (e.g. red teaming), model adaptations, including alignment and fine-tuning.
26.2.3	Where applicable, a detailed description of the system architecture explaining how software components build or feed into each other and integrate into the overall processing.

5.8 Transparency information for providers of GPAI to downstream providers

ID: 26.3 (version 1.0)	Technical documentation for providers of general-purpose AI models to downstream providers that integrate the model into their AI system must contain at least the following (based on Annex XII EU AI Act)
26.3.1	A general description of the general-purpose AI model including: a) the tasks that the model is intended to perform and the type and nature of AI systems into which it can be integrated; b) the acceptable use policies applicable; c) the date of release and methods of distribution; d) how the model interacts, or can be used to interact, with hardware or software that is not part of the model itself, where applicable; e) the versions of relevant software related to the use of the general-purpose AI model, where applicable; f) the architecture and number of parameters; g) the modality (e.g. text, image) and format of inputs and outputs; h) the license for the model.

26.3.2	A description of the elements of the AI model and of the process for its development, including: a) the technical means (e.g. instructions for use, infrastructure, tools) required for the general-purpose AI model to be integrated into AI systems; b) the modality (e.g. text, image, etc.) and format of the inputs and outputs and their maximum size (e.g. context window length, etc.); c) information on the data used for training, testing and validation, where applicable, including the type and provenance of data and curation methodologies.
--------	--

6 Roles and Responsibilities

6.1 Creator

The creator of the ICT Risk AI Guideline is the ICT Risk Governance & Advisory Unit (Specialist).

The creator of ICT Risk AI Guideline has the responsibility to issue clear, precise, and appropriate written rules to give guidance for implementation to the target group. It is important to ensure that all required information is accurate, up to date and complete.

6.2 Guideline Owner

The owner of the ICT Risk AI Guideline is Head of ICT Risk Governance & Advisory Unit and LE CISOs (in case of adoption).

The most important tasks (not an exhaustive list) within the scope of responsibility are:

- Ensure completeness of Guideline within functional area of responsibility
- Ensure correctness of content and the Guideline is up to date
- Define and conduct adherence oversight measures for Guidelines on a regular basis
- Assess impact on the Guideline with major focus on requirements as well as roles and responsibilities in the event of organizational changes, new products etc.

The Guideline Owner has at least an Expert or Head of Unit level (or LE pendant in case of adoption).

The Guideline Owner is responsible for publishing and updating the ICT Risk AI Guideline according to established procedures within the organization.

7 Appendix

7.1 Contact Information

Written Rule Owner: Head of ICT Risk Governance & Advisory

Please contact ICT Risk Governance & Advisory in case of any questions related to this Guideline.

7.2 Document History

Document History

Version	Date	Changes & Background
1.0	01.04.2026	Initial set-up of this Guideline

Coordination before publication

Version	Date	Task	Name
1.0	21.11.2025	Creator	ICT Risk Governance & Advisory (Specialist)
	03.03.2026	Content Review	LE CISOs TISOs
	05.03.2026	Content Confirmation	Head of ICT Risk Governance & Advisory Unit and LE CISOs

Approvals

Version	Date	Task	Name
1.0	06.03.2026	Approval	DBAG Chief Risk Officer (or LE pendant in case of adoption).

7.3 Related Written Rules

Superordinated Written Rules	• ICT Risk Management Policy
Subordinated Written Rules	• AI Procedure on AI System Classification

7.4 Supporting Document(s)

Other referenced Written Rules	• Data Protection Policy (Personal Data) • Guideline on Data Protection • Policy on IT Compliance, Artificial Intelligence and Segregation of Duties • Guideline on Artificial Intelligence (Group Compliance) • AI Code of Conduct • Data Governance Guideline
--------------------------------	---

7.5 Abbreviations

The abbreviations in this document are defined in the overall ICT Risk Glossary, which is provided on the Intranet website.

***** END OF DOCUMENT *****
